OnBuch+

SIGNED COURSE • PREMIUM

ICT • UPPER SIXTH | UPPER SIXTH — ICT

CHAPTER 6

IMPLEMENTATION OF NETWORK SECURITY

SUGGESTED TIME: 6 PERIODS

IN THIS CHAPTER

This chapter explains how organisations interconnect and protect their networks: intranets, extranets and VPNs, threats and security mechanisms, data protection and access control, and data validation and verification techniques. It prepares Upper Sixth students to design, justify and evaluate security solutions for the GCE Advanced Level examination.

- By the end of this chapter I can distinguish an intranet, an extranet and the Internet and give a Cameroonian use case for each.
- By the end of this chapter I can explain how a VPN creates a secure tunnel over a public network and name common tunnelling protocols.
- By the end of this chapter I can identify the main threats to computers and networks (malware, phishing, DoS, spoofing, interception) and match each to a countermeasure.
- By the end of this chapter I can describe the roles of firewalls, antivirus software, encryption, authentication and backups in a defence-in-depth strategy.
- By the end of this chapter I can explain symmetric and asymmetric encryption and the use of digital signatures and certificates.
- By the end of this chapter I can design an access-control policy using user accounts, passwords, biometrics and access levels (read/write/execute).

DOWNLOAD ONBUCH
Free • Google Play
AI tutor, past papers, results

GO ONBUCH+
All signed courses, unlimited AI tutor, PDF sheets — OnBuch+ tab in the app

THIS SIGNED COURSE CONTAINS

COURSE complete, illustrated, step by step

METHODS and worked examples

EXERCISES exam style + solutions

SUMMARY SHEET the essentials to remember

CONTENTS

1. Intranets and Extranets
2. Virtual Private Networks (VPNs) and Privacy
3. Computer and Network Security: Threats and Countermeasures
4. Data Protection and Access Control
5. Data Validation, Verification and Integration
6. Integration activity
7. Methods and worked examples
8. Exercises
9. Solutions to the exercises
10. Summary sheet

CHAPTER OBJECTIVES

- By the end of this chapter I can distinguish an intranet, an extranet and the Internet and give a Cameroonian use case for each.
- By the end of this chapter I can explain how a VPN creates a secure tunnel over a public network and name common tunnelling protocols.
- By the end of this chapter I can identify the main threats to computers and networks (malware, phishing, DoS, spoofing, interception) and match each to a countermeasure.
- By the end of this chapter I can describe the roles of firewalls, antivirus software, encryption, authentication and backups in a defence-in-depth strategy.
- By the end of this chapter I can explain symmetric and asymmetric encryption and the use of digital signatures and certificates.
- By the end of this chapter I can design an access-control policy using user accounts, passwords, biometrics and access levels (read/write/execute).
- By the end of this chapter I can apply data validation techniques (range, type, format, presence, length, check digit) and verification techniques (double entry, proofreading) to a data-entry form.
- By the end of this chapter I can evaluate the security of a small organisation's network and propose justified improvements, as expected in GCE problem-solving questions.

PREREQUISITES

- Network topologies, transmission media and network devices (Lower Sixth: networks chapter).
- The Internet, IP addressing, clients and servers, and the client–server model.
- Basic notions of data, information and databases (fields, records, data types).
- Number bases and binary representation of data (useful for encryption and check digits).
- General ICT ethics and legislation notions seen in Lower Sixth.

1 INTRANETS AND EXTRANETS

In Yaoundé, a cybercafé owner discovers that a customer used his Wi-Fi to empty a mobile-money agent's account, and the police trace the traffic back to his router. Meanwhile, a bank with branches in Douala, Bafoussam and Bamenda must let its staff share files as if they were in one office, without exposing customer data on the public Internet. Students themselves log into school result portals and WhatsApp every day, often on open hotspots at Mokolo market. Who can see their passwords? How can an organisation open its network just enough to be useful, yet keep intruders out? This chapter answers these questions by showing how intranets, extranets, VPNs, security mechanisms and access control protect data in real Cameroonian institutions.

The first step is to understand that not every network is "the Internet". Organisations build private networks that use exactly the same technologies as the Internet, but with locked doors. These are the **intranet** and the **extranet**.

1.1 What is an Intranet?

Intuition first. Imagine the staff room of a large school. Inside, teachers pin circulars on a notice board, share a common cupboard of files, and consult the staff list. None of this is visible from the street: you must be a member of staff to enter. An intranet is exactly this idea, built with computers: the organisation uses the same tools as the public Internet (web pages, browsers, email), but only its own members may open the door.

DEFINITION **Intranet**

An **intranet** is a private computer network that uses Internet technologies (the TCP/IP protocol suite, web browsers, web servers, email) but whose access is restricted to the members of one organisation (employees, students, staff). It is not reachable from the public Internet.

KEY POINTS **Key idea: same tools, restricted doors**

An intranet is not a different technology from the Internet. It uses the same tools (TCP/IP, HTTP, browsers such as Chrome or Firefox) but with restricted doors: firewalls and user accounts ensure that only authorised members can connect. Remember the formula: "same tools, restricted doors".

Services offered by an intranet. A well-built intranet typically provides:

- **Internal web pages**: news, circulars, policies, canteen menus, published on an internal web server and read with an ordinary browser.
- **File sharing**: a central file server where departments store and exchange documents instead of carrying flash drives from office to office.

- **Internal email**: messages between staff that never leave the organisation's servers.
- **Shared databases**: e.g. the student records database of a university, queried by all faculties.
- **Staff directories**: searchable lists of employees, offices and telephone extensions.
- **E-learning platforms**: internal Moodle-style platforms for training staff or delivering lessons.

EXEMPLE **A bank's intranet in Cameroon**

A commercial bank with branches in Douala, Bafoussam and Bamenda connects all its branches into one intranet. A clerk in Bamenda opens the same internal web application as a clerk in Douala to check a customer's file; the human-resources department publishes circulars on the internal portal; internal email carries daily reports to headquarters. A person sitting in a cybercafé across the road cannot reach any of these pages: the intranet is invisible from the public Internet.

1.2 What is an Extranet?

Intuition first. Sometimes the staff room must receive selected visitors: the book supplier may consult the school's order page, but not the exam marks. The school does not open the whole staff room to the street; it creates a small controlled area where identified partners may enter with a badge. That controlled extension is an extranet.

DEFINITION **Extranet**

An **extranet** is a controlled extension of an intranet that grants limited access to authorised external partners — suppliers, banks, ministries, parent companies, affiliated institutions — so that they can exchange specific data with the organisation, without seeing the whole internal network.

EXEMPLE **Cameroonian extranets**

- A university extranet allows its affiliated colleges to upload student transcripts and download official templates, while the internal payroll and disciplinary files remain invisible to them.
- MINEDUB / MINESEC portals allow authorised schools to submit examination entries and consult official results online: each school logs in with its own credentials and sees only its own candidates.
- A manufacturer in Bonabéri lets its main suppliers consult stock levels so they can plan deliveries — nothing more.

1.3 Internet, Intranet, Extranet: a Systematic Comparison

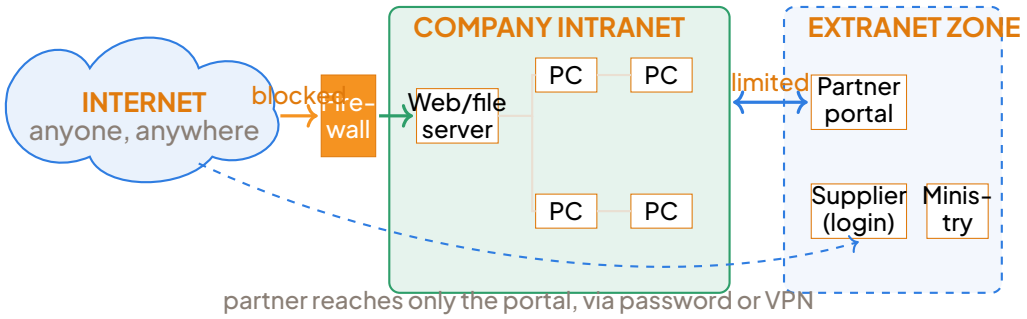
METHOD **Classifying a network: three questions**

To classify a network as Internet, intranet or extranet, ask three questions, in order:

1. Who owns it? (the public at large / one organisation / one organisation plus partners)
2. Who can log in? (anyone / members only / members and selected outsiders)
3. What can they reach? (everything public / all internal services / only a limited, agreed subset)

The answers immediately give the classification.

Criterion	Internet	Intranet	Extranet
Ownership	Public, global, no single owner	One organisation	One organisation, shared with partners
Users	Anyone in the world	Members of the organisation only	Members + authorised external partners
Access rights	Open; no login needed for public pages	Login required; firewall blocks outsiders	Login required; each partner sees a limited zone
Security level	Low by default (open network)	High (private, controlled)	Medium to high (controlled openings)
Cameroonian example	Google, Facebook, public websites	A bank's internal portal linking its branches	MINESEC portal for authorised schools



Three zones: the open Internet, the private intranet behind a firewall, and the extranet zone where identified partners reach a limited portal.

1.4 Setting up an Intranet: Hardware and Software

PROPERTY **Requirements for an intranet**

To set up an intranet, an organisation needs: (a) a local area network (LAN) — switches, cables or Wi-Fi access points — interconnecting the users' computers; (b) at least one server, a powerful computer that hosts the services; (c) server software: a web server (e.g. Apache, Nginx), a mail server (e.g. Postfix, Microsoft Exchange), and a database management system (e.g. MySQL, PostgreSQL); (d) user accounts and passwords managed by an administrator (directory service such as Active Directory or OpenLDAP); and (e) a firewall separating the intranet from the public Internet.

WARNING **Do not confuse an intranet with a simple LAN**

A LAN is only the hardware: cables, switches and computers in one site. An intranet is defined by its services (internal web, mail, shared databases) and its restricted access, and it can span several sites (Douala, Bamenda, Bafoussam) linked together. A LAN with no internal web or mail services is not yet an intranet. In the GCE, writing "an intranet is a LAN" loses the mark.

1.5 Advantages and Limitations

Advantages	Limitations / risks
Higher productivity: information is found in seconds, shared instantly.	Cost of servers, software licences and a network administrator.
Lower communication costs (no printing of circulars, fewer trips between branches).	Confidentiality risk: a badly configured server or weak password can expose internal data to the Internet.
Better confidentiality than public tools: data stays on the organisation's own servers.	Requires staff training; an unused intranet is wasted money.
Extranets speed up business: partners serve themselves (orders, results, stock).	Each external opening is a potential door for attackers; access rights must be reviewed regularly.

WORKED EXAMPLE 1 **Classifying three networks**

A student writes: "(1) The website where anyone reads Cameroon's news; (2) the internal portal where only employees of a Douala brewery read circulars and share files; (3) the portal where authorised secondary schools submit GCE entries to the GCE Board." Classify each network and justify.

SOLUTION

Solution. Apply the three questions (owner? users? reachable content?).

1. Internet: owned by no single body, open to anyone, all public pages reachable.
2. Intranet: owned by one company, restricted to its employees only, all internal services (circulars, file sharing) reachable by them, invisible from outside.
3. Extranet: owned by the GCE Board, but access is extended to authorised external partners (the schools), each limited to its own candidates' data — a controlled opening of an internal system.

DID YOU KNOW? **Exam tip: earn application marks**

GCE examiners reward application. Whenever you define an intranet or extranet, illustrate it with a named Cameroonian organisation: a bank's branch network, a university's affiliated colleges, the MINESEC/MINEDUB portals, or a mobile-money operator's internal systems. A definition plus a local example typically earns full marks.

EXERCISE 1 **Your school's network**

Your school wants (a) an internal site where teachers post marks and circulars, and (b) a page where the parents' association can consult only the school calendar and fee notices. List the hardware and software needed, and state which part is an intranet and which is an extranet, justifying with the three classification questions.

SOLUTION **Exercise 1**

Hardware: a LAN (switch, cabling or Wi-Fi), one server, staff computers; a firewall toward the Internet. Software: web server (e.g. Apache), mail server, database, and user accounts with passwords. Part (a) is the intranet: owned by the school, restricted to staff, all internal services reachable. Part (b) is an extranet: identified external partners (the parents' association) receive a login but reach only a limited zone (calendar, fees), never the marks.

WARNING **Link forward: how does an extranet stay private?**

An extranet lets outsiders in through the public Internet — so how is the traffic protected?

Two mechanisms are used: password-protected portals (HTTPS websites with individual accounts) and Virtual Private Networks (VPNs), which build an encrypted tunnel between the partner and the organisation. This is exactly the subject of the next section.

2 VIRTUAL PRIVATE NETWORKS (VPNS) AND PRIVACY

In the previous section we saw how an **intranet** keeps an organisation's information inside the organisation, and how an **extranet** opens a controlled door to trusted partners. Both solutions assume that users are physically close to the private network, or connected through expensive leased lines. What happens when the accountant of a microfinance institution in Bamenda must reach the head-office server in Yaoundé, using nothing but the ordinary public Internet? The answer is the **Virtual Private Network**, and the broader question of **privacy** on public networks.

2.1 Why Privacy Is at Risk on Public Networks

A concrete observation.

Imagine you connect your laptop to the free Wi-Fi hotspot of a busy restaurant in Douala and open your webmail. Between your laptop and the mail server, your data travels as **packets** through equipment you do not control: the restaurant's router, the access provider's network, possibly several intermediate operators. At every one of these points, the packets can in principle be copied and read. This is called **packet interception** (or "sniffing").

Three facts make privacy fragile on public networks:

- **Packet interception.** Tools such as packet sniffers capture everything that crosses a network segment. If the traffic is not encrypted, passwords, messages and account numbers are readable in plain text.
- **Open Wi-Fi hotspots.** On an open hotspot, anyone within radio range can listen. Worse, an attacker can set up a fake hotspot with a convincing name (an "evil twin") and relay all your traffic through his own machine — a man-in-the-middle position.
- **ISP visibility.** Your Internet Service Provider (the company that sells you the connection) necessarily sees which servers you contact and, for unencrypted traffic, the content itself. The ISP is part of the path, so it is part of the trust problem.

WARNING **The public network is not yours**

Never treat the public Internet as a private wire. Any information sent unencrypted over a public network must be considered as potentially read, copied or modified by a third party. This single idea justifies almost everything in this chapter.

2.2 Definition of a VPN and of Tunnelling

The intuition is simple: if we cannot make the public network private, we can build a private passage inside the public network. Think of sending a valuable parcel through the ordinary post: you cannot trust the post, so you lock the parcel in a strongbox before posting it. Anyone who intercepts the box sees only a locked box.

DEFINITION **Virtual Private Network (VPN)**

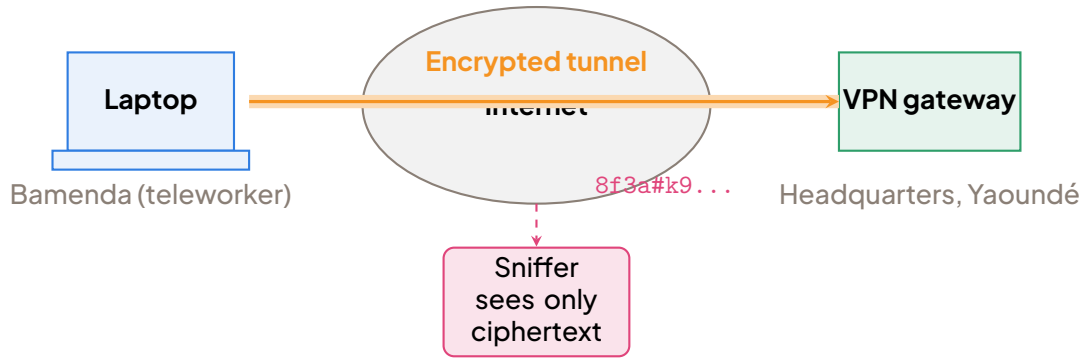
A **Virtual Private Network** is a private, encrypted logical connection — called a **tunnel** — established between two **endpoints** over a public network such as the Internet. It is virtual because no dedicated physical cable exists, and private because encryption makes the content unintelligible to anyone on the public path.

DEFINITION **Tunnelling**

Tunnelling is the technique used by a VPN: each original packet (with its data, called the payload) is first encrypted, then encapsulated — wrapped inside a new packet whose header contains only the public addresses of the two endpoints. On the public Internet, only the outer envelope is visible; the protected content travels inside it, exactly like the strongbox inside the postal parcel.

The mechanism therefore has three ingredients:

1. **Encapsulation:** the original packet becomes the payload of a new packet addressed to the VPN gateway.
2. **Encryption:** the payload is ciphered with a secret key shared by the endpoints, so interception reveals only ciphertext.
3. **Endpoints:** the tunnel has exactly two ends — typically a VPN client (software on the user's machine) and a VPN server or VPN gateway (a dedicated device at the organisation's border). Only the endpoints hold the keys.



A VPN tunnel: the teleworker's packets are encrypted before entering the public Internet; a sniffer on the path captures only unreadable ciphertext.

KEY POINTS **Key terms**

- **Encapsulation**: wrapping a packet inside another packet for transport.
- **Encryption**: transforming readable data (plaintext) into unreadable data (ciphertext) using a key, reversible only by the key holder.
- **Endpoint**: one of the two extremities of the tunnel (client or gateway) that encrypts and decrypts.
- **Protocol**: the agreed set of rules governing how the tunnel is negotiated, encrypted and maintained.

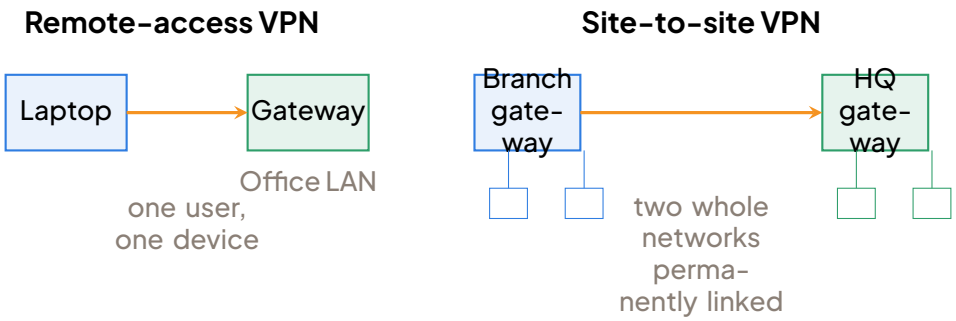
2.3 The Two Main Types of VPN

Remote-access VPN.

A single user — a teleworker, a travelling salesman, a student — connects his device to the organisation's network through VPN client software. The tunnel runs from the device to the VPN gateway. Once connected, the user works as if he were plugged into the office LAN: he can reach the intranet, the file server, the internal database.

Site-to-site VPN.

Two whole networks are permanently linked: the branch office in Buea and the headquarters in Yaoundé each have a VPN gateway, and the tunnel runs between the gateways. Users in the branch do nothing special; their traffic to headquarters is automatically encrypted by their local gateway and decrypted by the remote one. This is how many Cameroonian banks link their branches to the head office without renting costly dedicated lines.



Remote-access VPN (one device to the office) versus site-to-site VPN (two gateways linking two LANs).

2.4 Common VPN Protocols

A VPN protocol defines how the tunnel is authenticated, encrypted and transported. Four families dominate, and the GCE expects you to know their relative strengths:

Protocol	Principle	Strengths and weaknesses
PPTP	Early Microsoft tunnelling protocol; easy to configure.	Fast and simple, but its encryption is now considered **weak**; avoid for sensitive data.
L2TP/IPsec	L2TP carries the tunnel; IPsec provides strong encryption.	**Strong security**, widely supported; slightly heavier and can be blocked by some firewalls.
OpenVPN	Open-source VPN running over SSL/TLS, highly configurable.	**Strong, flexible, audited**; needs client software installation.
SSL/TLS VPN	Tunnel inside the same encryption as secure web browsing (HTTPS).	Works through almost any firewall, often browser-based; ideal for **remote access**.

PROPERTY **What a VPN guarantees — and what it does not**

A correctly configured VPN provides confidentiality (nobody on the path can read the traffic) and integrity (any modification of a packet in transit is detected) between the two endpoints. It does not provide anonymity from the VPN provider: the provider's gateway decrypts your traffic and can see where it goes next. A VPN protects the path, not the endpoints. (Statement to know; proof not examinable.)

2.5 Privacy Concepts and the Limits of VPNs

Three vocabulary distinctions are essential at this level:

- **Confidentiality** means that unauthorised persons cannot read the data. Encryption pro-

vides confidentiality.

- **Anonymity** means that observers cannot tell who is communicating. A VPN hides you from the local hotspot and from your ISP, but the VPN provider itself knows who you are — so a VPN gives partial privacy, not full anonymity.
- **Data in transit vs data at rest.** A VPN protects data in transit (moving across the network). Once the data arrives and is stored on a disk (at rest), the tunnel no longer protects it: disk encryption, passwords and access control — studied in the next section — take over.

WARNING **"My VPN makes me invisible" — false!**

The most common mistake is believing that a VPN makes a user completely invisible. In reality: (1) the VPN provider can see and log your traffic; (2) websites can still identify you through accounts and cookies; (3) malware already on your device is unaffected by the tunnel. A VPN is one layer of protection, never the whole solution.

DID YOU KNOW? **VPNs at work in Cameroon**

VPNs are not exotic technology here. Commercial banks use site-to-site tunnels to link branches to their data centres; NGOs connect field offices in the Far North to coordination offices in Yaoundé; mobile-money operators secure their back-office links between agents' systems and central platforms; and students and researchers use remote-access VPNs to reach academic resources that are restricted to certain regions or institutions.

Legal and ethical note (GCE-useful extra).

Using a VPN is, in itself, a legitimate act of privacy protection — companies and administrations do it daily. However, encryption never legalises an illegal act: fraud, defamation or hacking committed through a VPN remain offences. In Cameroon, Law No. 2010/012 relating to cybersecurity and cybercriminality punishes unauthorised access, interception and electronic fraud, whatever tunnelling technology is used. The ethical rule is simple: a VPN protects legitimate privacy; it is not a licence to harm.

2.6 Choosing a VPN Solution: Method and Worked Example

METHOD **Choosing a VPN solution**

1. Identify the users: individual mobile workers (remote access) or entire sites (site-to-site)?
2. Identify the required security level: sensitivity of the data determines whether weak protocols (PPTP) are excluded.
3. Assess constraints: budget, existing equipment, firewall restrictions, technical skills

available.

4. Select the protocol and product: e.g. SSL/TLS or OpenVPN for roaming users, L2TP/IPsec or site-to-site gateways for branches.
5. Test and document: verify encryption is actually active and train the users.

WORKED EXAMPLE 2 **Choosing a VPN for an NGO**

Statement. An NGO has its coordination office in Yaoundé and three small field offices in other regions. In addition, five project officers travel constantly and must reach the intranet from hotels and cybercafés. The budget is limited and the data (beneficiary files) is sensitive. Propose a VPN architecture and justify the protocol choices.

SOLUTION

Solution. Following the method: (1) Two populations of users exist — whole sites and mobile individuals — so both VPN types are needed. (2) The data is sensitive, so PPTP is excluded. (3) The budget is limited, so open-source or built-in solutions are preferred. Proposal: a site-to-site VPN using IPsec-capable gateways (or OpenVPN on low-cost routers) permanently links each field office to Yaoundé; a remote-access VPN based on OpenVPN or SSL/TLS serves the five travelling officers, because SSL/TLS passes through hotel firewalls easily. (4) The Yaoundé gateway authenticates every tunnel with strong credentials. (5) Before deployment, staff verify that intercepted traffic shows only ciphertext, and officers are trained never to disable the VPN on public Wi-Fi. This architecture protects data in transit on every public link while remaining affordable.

EXERCISE 2 **Checking your understanding**

1. Explain, in two sentences, the difference between encapsulation and encryption in a VPN tunnel.
2. A businessman in Douala says: “With my VPN, nobody on Earth can know which sites I visit.” Correct his statement precisely.
3. For each situation, choose remote-access or site-to-site VPN and justify: (a) a bank linking 20 branches to its head office; (b) a consultant working from home twice a week.
4. Why does a VPN not protect data at rest? Which complementary measures would you propose?

SOLUTION **Exercise: Checking your understanding**

1. Encryption transforms the packet's payload into unreadable ciphertext using a key; encapsulation then wraps this protected packet inside a new packet carrying the public addresses of the endpoints so it can cross the Internet.
2. False. The VPN hides his traffic from the hotspot and his ISP, but the VPN provider decrypts the traffic at its gateway and can see (and log) the sites visited; the sites themselves can also identify him through accounts and cookies.
3. (a) Site-to-site: entire networks must be linked permanently and transparently for all staff. (b) Remote-access: a single user on a single device connects occasionally to the office network.
4. The tunnel only protects data while it travels; once stored on a server or laptop, the data is outside the tunnel. Complementary measures: disk/file encryption, strong authentication and access control, and regular backups.

KEY POINTS **To remember**

A VPN builds an encrypted tunnel over a public network by encapsulating and encrypting packets between two endpoints. Remote-access VPNs serve individual users; site-to-site VPNs link whole networks. Prefer strong protocols (OpenVPN, L2TP/IPsec, SSL/TLS) over PPTP. A VPN guarantees confidentiality and integrity in transit, but it protects neither the endpoints nor data at rest, and it never makes you invisible to the VPN provider.

3 COMPUTER AND NETWORK SECURITY: THREATS AND COUNTERMEASURES

In the previous section we saw how a VPN protects data in transit by tunnelling and encryption. But a VPN is only one piece of the puzzle. A company in Douala may encrypt its traffic perfectly and still lose everything because an employee clicked on a fake MTN Mobile Money SMS, because a virus entered through a USB key, or because a power surge destroyed the only server. Security must therefore be studied globally: we must know what we are protecting, against which threats, and with which countermeasures. That is the purpose of this section.

3.1 Security Goals: the CIA Triad

Before studying attacks, we must know what "secure" means. All of computer security rests on three goals, known as the **CIA triad**.

DEFINITION **The CIA Triad**

A system is said to be secure when it guarantees:

- **Confidentiality**: information is accessible only to authorised persons.
- **Integrity**: information is accurate and complete; it cannot be modified or destroyed by unauthorised persons.
- **Availability**: information and services are accessible to authorised users when they need them.

EXEMPLE **One violation of each goal**

- Confidentiality violated: a hacker intercepts the exam results database of a school in Bamenda before publication and sells the marks.
- Integrity violated: a student breaks into the school server and changes his mark in ICT from 08/20 to 17/20. The data still exists, but it is no longer true.
- Availability violated: on the day of online registration, a denial-of-service attack floods the university website; thousands of candidates cannot register. The data is intact and confidential, but unreachable.

WARNING **Do not confuse the three goals**

Encryption protects confidentiality, not availability. A backup protects availability, not confidentiality. In the GCE exam, always state which goal a given measure protects.

3.2 Malware: the Main Families

DEFINITION **Malware**

A **malware** (malicious software) is any program designed to harm a system, steal data, or operate without the user's consent.

The virus.

A **virus** is a piece of code that attaches itself to a legitimate program or document and spreads when that program is executed or the file is shared (USB keys, email attachments). It needs a human action to spread. It can delete files, corrupt data or open a backdoor.

The worm.

A **worm** spreads by itself through the network, exploiting software vulnerabilities, without any human action. Because it replicates automatically, a worm can infect thousands of machines in a few hours and saturate networks.

The Trojan horse.

A **Trojan horse** hides inside an apparently useful program (a free game, a cracked application). It does not replicate; once installed, it opens a hidden access for the attacker, who can then spy on or control the machine remotely.

Ransomware.

Ransomware encrypts the victim's files and demands a ransom (often in cryptocurrency) for the decryption key. Hospitals and town councils worldwide have been paralysed by such attacks. The only reliable defence is a recent offline backup.

Spyware.

Spyware secretly collects information: typed passwords (keyloggers), visited sites, documents. It is often installed with free software.

Adware and rootkits.

Adware displays unwanted advertisements and may track browsing habits. A **rootkit** modifies the operating system to hide its own presence and that of other malware, making detection extremely difficult.

Malware	How it spreads	Main damage
Virus	Attached to files/programs, needs human action	Corrupts or deletes data
Worm	Self-replicates through network vulnerabilities	Massive infection, network saturation
Trojan horse	Hidden in attractive software	Remote control, backdoor
Ransomware	Email, downloads, vulnerabilities	Encrypts files, ransom demand
Spyware	Bundled with free software	Steals passwords and data
Adware	Bundled, malicious websites	Unwanted ads, tracking
Rootkit	Exploits privileges, Trojan	Hides malware, persistent access

3.3 Human and Social Attacks

Technology is often stronger than the humans using it. **Social engineering** consists of manipulating people rather than breaking machines.

Phishing.

Phishing is a fake message (SMS, email, website) imitating a trusted organisation to steal credentials or money. Example: an SMS reading "MTN MoMo: your account is blocked. Confirm your PIN at mtn-verify.com" or "Your bank: unusual login detected, enter your card number to secure your account". The link leads to a fake page that captures the PIN. **Spear phishing** targets a specific individual or organisation with personalised details.

Pretexting.

Pretexting is building a false scenario to gain trust: a caller pretends to be "the IT technician of

the bank" and asks the employee to "confirm" his password to fix an incident.

Baiting and tailgating.

Baiting leaves infected USB keys in public places (parking lot, reception) labelled "Salaries 2024" or "Exam Papers". **Tailgating** (piggybacking) follows an authorised person through a secure door without a badge.

Weak-password guessing.

Attackers try common passwords (123456, password, first names, birth dates) or use dictionaries. A short, predictable password falls in seconds. **Brute-force** attacks try all combinations; **dictionary attacks** try common words.

> **WARNING** **The human is the weakest link**
>
> No firewall can prevent an employee from giving his password to a polite caller. Security = **technology** + **policy** + **trained users**.

3.4 Network Attacks

Interception / sniffing.

A **sniffer** captures packets travelling on a network. On an unencrypted Wi-Fi network (e.g. an open hotspot), passwords and messages sent in plain text can be read directly. Countermeasure: encryption (HTTPS, VPN, WPA2/WPA3).

IP spoofing.

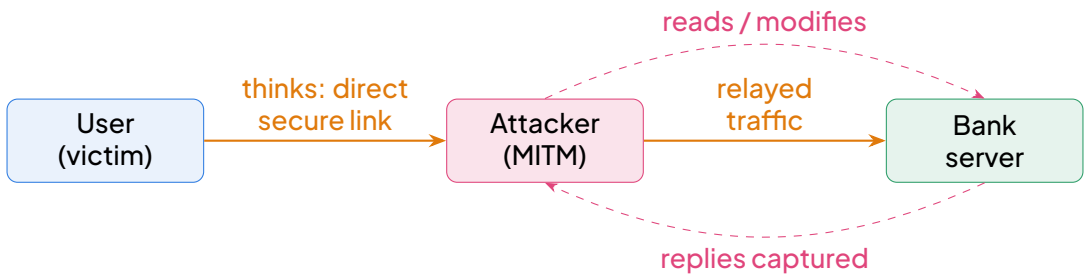
IP spoofing consists of forging the source IP address of packets to impersonate a trusted machine and bypass address-based filters.

Denial of service (DoS / DDoS).

A **DoS** attack floods a server with requests until it can no longer answer legitimate users. In a **DDoS** (distributed DoS), the flood comes from thousands of infected machines (a **botnet**). Goal violated: availability. Common vectors: SYN flood, UDP amplification, HTTP flood.

Man-in-the-middle (MITM).

In a **man-in-the-middle** attack, the attacker secretly places himself between two communicating parties, relaying and possibly reading or modifying their messages, while each believes it is talking directly to the other. Variants: ARP spoofing (local network), DNS spoofing (redirects to fake site), SSL stripping (downgrades HTTPS to HTTP).



Man-in-the-middle attack: the attacker relays traffic between the victim and the bank server while both believe they communicate directly.

SQL injection and cross-site scripting (XSS).

SQL injection inserts malicious SQL code into input fields to read, modify or delete database content. **XSS** injects malicious scripts into web pages viewed by other users, stealing session cookies or defacing sites. Both exploit insufficient input validation.

3.5 Physical Threats and Physical Countermeasures

Security is not only software. **Physical threats** include:

- **Theft of equipment**: laptops and servers stolen from an office in Yaoundé, with all their data.
- **Power cuts and surges**: frequent load-shedding can corrupt disks and destroy hardware.
- **Fire and floods**: a server room without protection can be destroyed in minutes.
- **Environmental damage**: humidity, dust, excessive heat.
- **Unauthorised physical access**: someone plugging a malicious device into a network port.

Physical countermeasures: locked server rooms with badge/biometric access, security guards, fire extinguishers and smoke detectors, raised floors in flood-prone areas, air conditioning, and **UPS** (uninterruptible power supplies) plus generators. Cable locks for laptops, port security (disabling unused switch ports), and secure disposal of storage media (degaussing, shredding).

3.6 Technical Countermeasures

DEFINITION **Firewall, antivirus, IDS, IPS**

- A **firewall** filters network traffic between zones of different trust levels (e.g. the Internet and the intranet), blocking or allowing packets according to rules.
- An **antivirus** (anti-malware) scans files and processes to detect, block and remove known malware using signatures and behaviour analysis (heuristics).
- An **IDS** (Intrusion Detection System) monitors network or system activity and alerts

administrators when suspicious patterns are detected.

- An **IPS** (Intrusion Prevention System) sits inline and can block suspicious traffic automatically in addition to alerting.

Three firewall techniques.

- **Packet filtering** (stateless): each packet is examined in isolation against rules (source/destination address, port, protocol). Fast, but blind to context.
- **Stateful inspection**: the firewall tracks the state of each connection (TCP handshake, sequence numbers) and only admits packets that belong to a legitimate, established session. More secure.
- **Application-layer firewall** (proxy firewall): understands application protocols (HTTP, FTP, DNS) and can inspect payload content, block specific commands, or filter URLs.

Wireless security.

Open Wi-Fi is a major risk. Standards evolution: WEP (broken), WPA (TKIP, deprecated), **WPA2** (AES-CCMP, mandatory since 2006), **WPA3** (SAE handshake, forward secrecy, mandatory since 2020). Enterprise mode (802.1X/RADIUS) uses individual credentials; Personal mode (PSK) uses a shared passphrase.

Updates and patches.

Most successful attacks exploit known vulnerabilities for which a **patch** already exists. Applying updates promptly to operating systems, applications, firmware and network devices is one of the cheapest and most effective countermeasures. **Vulnerability scanning** (e.g. Nessus, OpenVAS) identifies missing patches and misconfigurations.

WARNING **Common mistake: each tool has ONE role**

A firewall does not stop a virus hidden in an email attachment that a user voluntarily opens; an antivirus does not block a DDoS flood; an IDS only detects — it does not block. Never write in an exam that "a firewall protects against all attacks".

3.7 Organisational Countermeasures

- **Security policy**: a written document defining rules (passwords, USB keys, remote access, sanctions) accepted by all staff. Must be reviewed annually.
- **Staff training**: regular awareness sessions on phishing, pretexting, baiting, tailgating and safe practices. Simulated phishing campaigns measure readiness.
- **Least-privilege principle**: each user receives only the access rights strictly needed for his or her job — a secretary does not need administrator rights on the payroll server.

- **Separation of duties**: critical tasks require two people (e.g. one creates a payment, another approves it) to prevent fraud.
- **Incident response plan**: a prepared procedure (who to alert, how to isolate machines, how to preserve evidence, how to restore, how to communicate) so that a successful attack does not become a catastrophe.
- **Change management**: all changes to production systems are documented, tested, approved and logged.
- **Audits and logging**: centralised logs (SIEM) reviewed regularly; periodic internal and external security audits.

3.8 Backups and Redundancy

- **Full backup**: copies all data. Simple to restore, but slow and space-consuming.
- **Incremental backup**: copies only what changed since the last backup (of any type). Fast and economical, but restoration needs the last full backup plus all increments in order.
- **Differential backup**: copies what changed since the last full backup. Restoration needs only the last full and the last differential.
- **The 3-2-1 rule**: keep **3** copies of data (original + 2 backups), on **2** different media types (disk, tape, cloud), with **1** copy off-site (different building or geographic region).
- **Off-site copies**: at least one backup must be stored in a different building (or cloud), otherwise a fire destroys data and backup.
- **Power redundancy**: in the Cameroonian context of frequent outages, a **UPS** gives a few minutes to shut down cleanly, and a generator keeps critical services running. Surge protectors guard against voltage spikes.
- **RAID and clustering**: RAID (Redundant Array of Independent Disks) protects against single-disk failure; clustering/failover protects against whole-server failure.

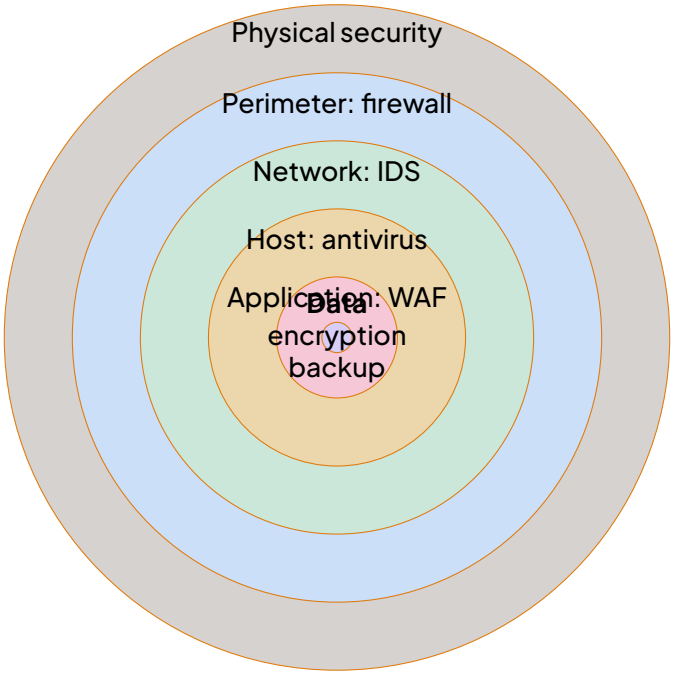
Backup type	What is copied	Restore complexity
Full	All files	Simple (one set)
Incremental	Changes since last backup (any type)	Complex (full + all increments)
Differential	Changes since last full backup	Moderate (full + last differential)

3.9 Defence in Depth

KEY POINTS **Defence in depth**

Never rely on a single protection. Layer several countermeasures — physical, perimeter, network, host, application, data — so that the failure of one layer is caught by the next.

This strategy is called **defence in depth**.



Defence in depth: concentric layers of protection around the data. An attacker must defeat every layer.

METHOD **Risk analysis in 4 steps**

1. List the assets: what must be protected (data, servers, reputation, business continuity).
2. List the threats: what could harm each asset (malware, theft, fire, phishing, DoS, insider).
3. Estimate the impact: likelihood (high/medium/low) and gravity (critical/major/minor) of each threat; compute risk level.
4. Choose countermeasures: for each significant risk, select proportionate technical, organisational and physical measures (avoid, mitigate, transfer, accept).

WORKED EXAMPLE 3 **Applying risk analysis to a cybercafé**

A cybercafé in Buea has 15 PCs, one server holding customer accounts, and an Internet

connection. Propose two security measures and justify each.

SOLUTION

Step 1 – Assets: customer account data, the 15 PCs, the Internet service.
Step 2 – Threats: malware via USB keys and downloads; power cuts; theft; phishing of customers.
Step 3 – Impact: malware is highly likely and would corrupt accounts (integrity, availability); power cuts are very frequent locally.
Step 4 – Countermeasures (two required):

1. Install and update an antivirus on all PCs — addresses the malware threat (protects integrity and availability of the machines).
2. Install a UPS on the server and schedule daily backups to an external disk kept off-site — addresses power cuts and data loss (protects availability).

Each measure is named together with the threat it addresses.

EXERCISE 3 **Threats and countermeasures**

A small microfinance institution in Douala stores its clients' savings records on one server connected to the Internet. Staff access it from the office and from home. Identify three threats (one malware, one network, one physical) and propose for each a suitable countermeasure, stating which CIA goal it protects.

SOLUTION **Exercise 1**

Possible answer (other correct choices exist):

- Malware – ransomware via a phishing email: countermeasure = updated antivirus + staff training + regular off-site backups; protects availability and integrity.
- Network – interception/sniffing of connections from home: countermeasure = VPN with encryption (HTTPS/IPsec); protects confidentiality.
- Physical – power cut or theft of the server: countermeasure = UPS + generator, locked server room, off-site backup copy; protects availability.

Threat	Countermeasure(s)	CIA goal
Virus, worm, ransomware	Antivirus, patches, backups	I, A
Phishing, pretexting, baiting	Training, security policy	C, I
Sniffing, MITM, ARP spoofing	Encryption (VPN, HTTPS, WPA3)	C, I
DoS / DDoS	Firewall, ISP filtering, redundancy	A
IP spoofing	Stateful firewall, authentication	C, I
SQL injection, XSS	Input validation, WAF, prepared statements	C, I, A
Theft, fire, flood, power cut	Locks, guards, UPS, generator, off-site backup	A
Unauthorised physical access	Port security, badge access, cable locks	C, I, A

Matching threats to countermeasures (C = confidentiality, I = integrity, A = availability).

DID YOU KNOW? **Exam tip**

GCE questions often ask you to "propose two measures to secure a network". A full-mark answer always names the measure AND the threat it addresses (and ideally the CIA goal protected). "Install a firewall" alone earns little; "install a stateful firewall to block unsolicited incoming connections (DoS, intrusion attempts), protecting availability" earns full credit.

DID YOU KNOW? **Cameroon context: ANTIC and cybersecurity law**

The Agence Nationale des Technologies de l'Information et de la Communication (ANTIC) is Cameroon's regulatory body for cybersecurity. Law No. 2010/012 on cybersecurity and cybercrime criminalises unauthorised access, data interception, system interference, and computer-related fraud. Organisations handling sensitive data (banks, telecoms, government) must comply with ANTIC guidelines and report incidents. The **Computer Emergency Response Team** (CERT-CM) coordinates incident response nationally.

KEY POINTS **Key points of the section**

- Security aims at **confidentiality**, **integrity** and **availability** (CIA).
- Malware families differ by how they spread and what they do: virus, worm, Trojan, ransomware, spyware, adware, rootkit.

- Social engineering (phishing, spear phishing, pretexting, baiting, tailgating) targets humans; network attacks (sniffing, spoofing, DoS/DDoS, MITM, SQLi, XSS) target communications; physical threats target equipment.
- Countermeasures are technical (firewall: packet/stateful/application; antivirus; IDS/IPS; patches; WPA3; WAF), organisational (policy, training, least privilege, separation of duties, incident response, change management, audits) and physical (locks, UPS, generator, off-site backups, port security, secure disposal).
- **Defence in depth**: layer the protections so that no single failure is fatal.
- **3-2-1 backup rule**: 3 copies, 2 media types, 1 off-site.
- Risk analysis: assets → threats → impact → proportionate countermeasures.

4 DATA PROTECTION AND ACCESS CONTROL

In the previous section we studied the threats that target computers and networks (viruses, phishing, denial of service, interception) and the countermeasures that block them (antivirus software, firewalls, updates). But even a network perfectly protected from outside attackers still faces a fundamental question: who is allowed to see or modify which data, and how do we prove that a user is really who he claims to be? A firewall stops strangers at the gate; it does not stop a dishonest clerk inside the office from reading the salary file. This section therefore deals with the protection of the **data itself**: keeping it confidential through **encryption**, guaranteeing its origin through **digital signatures**, verifying identity through **authentication**, and limiting actions through **access control**.

4.1 Why Data Must Be Protected

A concrete observation. At the end of each term, a school in Bamenda produces report cards. The marks file contains personal data (names, dates of birth), academic data (marks, averages) and sometimes financial data (fee balances). Imagine three incidents: (1) a student opens the marks file and changes his Physics mark from 09 to 19; (2) a USB key containing the file is lost in a taxi; (3) a stranger phones the school pretending to be a parent and asks for a child's results. In all three cases the network was not attacked at all — the data was simply not protected.

Data must be protected because of three requirements, often called the **CIA triad**:

- **Confidentiality**: only authorised persons can read the data (a student's results are private).
- **Integrity**: data cannot be modified or destroyed without authorisation (a mark validated by the class council must not change afterwards).
- **Availability**: authorised users can access the data when needed (the bursar must reach the fees database on registration day). Availability is ensured by regular **backups**, redundant equipment and protection against denial-of-service attacks.

DEFINITION **Data privacy and data protection**

Data privacy is the right of a person to control how information about him or her (**personal data**: name, address, health, finances, exam results) is collected, stored, used and shared. **Data protection** is the set of technical and organisational measures used to guarantee the confidentiality, integrity and availability of data.

Internationally recognised data-protection principles include: collect only the data you need (**data minimisation**), use it only for the declared purpose, keep it accurate, keep it no longer than necessary, secure it, and be accountable for it. In Cameroon, Law No. 2010/012 on cybersecurity and cybercriminality, together with the work of the National Agency for Information and Communication Technologies (**ANTIC**), provides the national framework for securing information systems and for sanctioning fraudulent access to, or alteration of, data. Banks, mobile money operators (MTN MoMo, Orange Money) and examination bodies such as the GCE Board all have a legal and moral duty to protect the personal data they hold.

DID YOU KNOW? **Did you know?**

ANTIC is the public body in charge of the security of State information systems in Cameroon. It also manages the national public key infrastructure used to issue electronic certificates to administrations, so that an official electronic document can be authenticated — exactly the digital-signature mechanism we study below.

4.2 Encryption: Making Data Unreadable to Strangers

Intuition. During the Second World War, armies sent orders by radio; anyone could listen, so the orders were scrambled with a machine and only the intended receiver, who owned the same machine settings, could unscramble them. Encryption is exactly this idea, done with mathematics.

DEFINITION **Encryption, plaintext, ciphertext, key, algorithm**

Encryption is the transformation of readable data, called the **plaintext**, into an unreadable form, called the **ciphertext**, using an **algorithm** (the encryption method) and a **key** (a secret value that parameterises the algorithm). The reverse operation is **decryption**. The security of a good system relies on the secrecy of the key, not of the algorithm.

EXEMPLE **A toy example: the Caesar cipher**

Shift every letter by 3 positions (the key is 3): the plaintext `EXAM` becomes the ciphertext `HADP` (E→H, X→A, A→D, M→P). Decryption shifts back by 3. This cipher is trivially weak

(only 25 possible keys, all testable by hand), but it illustrates the vocabulary: algorithm = shifting letters, key = the shift value. Modern algorithms such as **AES** use keys of 128 or 256 bits, giving an astronomically large number of possibilities (2^{128} is about 3.4×10^{38}).

Symmetric encryption. In **symmetric encryption**, the same secret key is used to encrypt and to decrypt. It is fast and is used to encrypt whole disks, databases and VPN tunnels (AES is the standard example). Its weakness is the **key-distribution problem**: before Alice and the bank can communicate secretly, they must both possess the same secret key — but how do they exchange this key safely if their only channel is the insecure Internet? Sending the key unprotected would let an eavesdropper copy it.

Asymmetric encryption. The elegant solution, invented in the 1970s, is **asymmetric encryption** (or public-key encryption). Each user generates a pair of mathematically linked keys: a **public key**, published freely (on a website, a key server), and a **private key**, kept strictly secret.

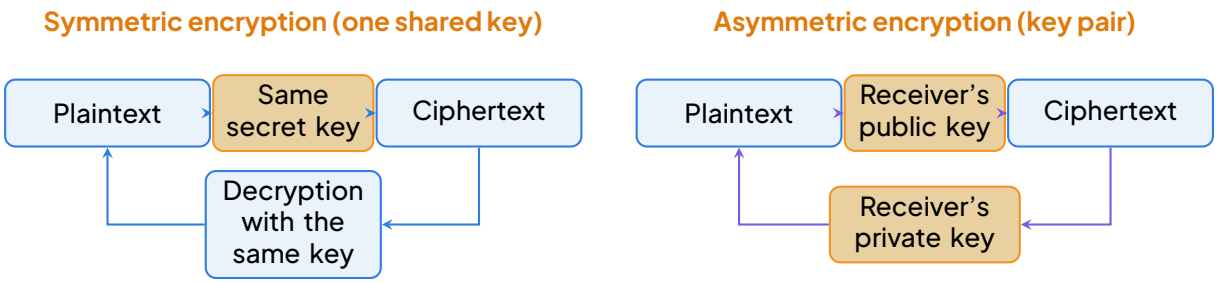
DEFINITION **Symmetric and asymmetric encryption**

In **symmetric encryption**, one shared secret key encrypts and decrypts (example: AES). In **asymmetric encryption**, each user owns a key pair: a **public key** known to everyone and a **private key** known only to its owner (example: RSA). What one key of the pair does, only the other key of the same pair can undo.

PROPERTY **Fundamental property of public-key cryptography**

If a message is encrypted with a public key, only the corresponding private key can decrypt it (this gives confidentiality). Conversely, if a message is transformed with a private key, anyone can verify it with the corresponding public key, and only the owner of the private key could have produced it (this gives authentication and underlies digital signatures). The property itself is examinable; its mathematical proof is not required.

This solves key distribution: to send a secret to the bank, I encrypt it with the bank's public key, which I can download openly. Only the bank's private key can read it. No shared secret ever travels on the network. In practice, asymmetric encryption is slow, so systems like HTTPS use it only to exchange a symmetric session key, which then encrypts the bulk of the traffic — the best of both worlds.



Symmetric encryption uses one shared key (fast, but the key must be exchanged secretly). Asymmetric encryption uses a public key to encrypt and the matching private key to decrypt, so no secret needs to travel.

Criterion	Symmetric (e.g. AES)	Asymmetric (e.g. RSA)
Keys	One shared secret key	A pair: public + private
Speed	Fast; suits large volumes	Slow; suits small amounts
Main problem	Distributing the shared key safely	Certifying that a public key is genuine
Typical use	Disks, databases, VPN tunnels, HTTPS bulk traffic	Key exchange, digital signatures, certificates

4.3 Hashing, Digital Signatures and Certificates

Hashing. Some protections do not need secrecy but fingerprints. A **hash function** takes data of any size and produces a short fixed-length code, the **hash** (or digest), with three essential properties: it is one-way (you cannot reconstruct the data from the hash), the smallest change in the data completely changes the hash, and it is practically impossible to find two different inputs with the same hash.

DEFINITION **Hashing**

Hashing is the application of a one-way mathematical function to data to obtain a fixed-length digest. Hashing is used (a) to store password hashes instead of the passwords themselves, so that even someone who steals the database cannot read the passwords, and (b) to check the integrity of a file: if the recomputed hash equals the published hash, the file has not been altered.

EXEMPLE **Checking a downloaded file**

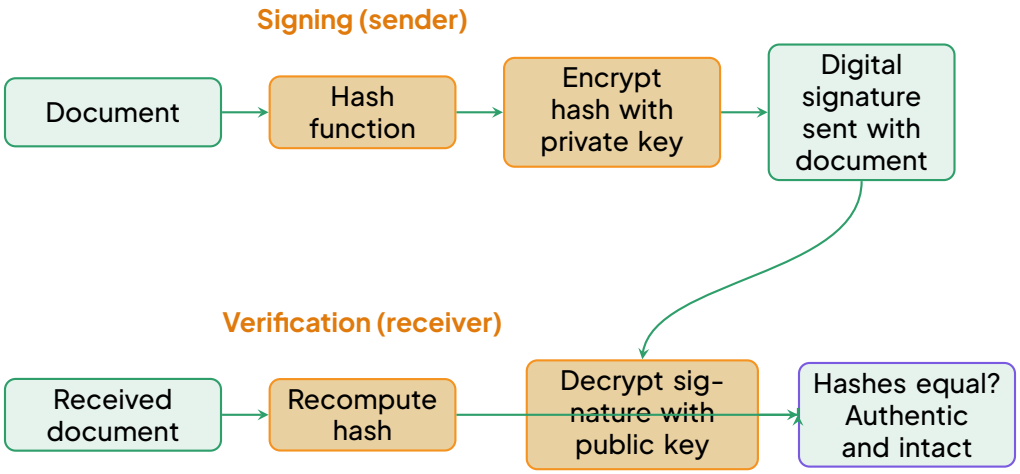
A ministry publishes a tax form together with its hash. After downloading, you recompute the hash of the file you received. If the two hashes match, the file is intact; if a single byte

was changed by an attacker or a transmission error, the hashes differ completely and you reject the file.

Digital signatures. Combining hashing with asymmetric encryption gives the **digital signature**, which answers: "Is this document really from the claimed sender, and was it modified?"

DEFINITION **Digital signature**

A **digital signature** is produced by hashing a document and encrypting the hash with the sender's private key. The receiver recomputes the hash of the received document and decrypts the signature with the sender's public key: if the two hashes match, the document is authentic (it comes from the private key's owner) and intact (it was not modified). The sender cannot later deny signing: this is **non-repudiation**.



A digital signature: the sender hashes the document and encrypts the hash with his private key; the receiver decrypts the signature with the sender's public key and compares it with a freshly computed hash.

Certificates and HTTPS. One question remains: how do I know that the "public key of the bank" really belongs to the bank and not to an attacker? This is the role of a **certification authority** (CA), a trusted organisation that verifies identities and issues **digital certificates**: a certificate binds a public key to an owner and is itself signed by the CA. When you visit a banking site in Douala and see the padlock and `https://` in the browser, the site has presented a certificate signed by a CA your browser trusts; your browser has verified it and set up an encrypted session. A certificate warning in the browser is a red flag: do not enter your MoMo PIN on such a page.

4.4 Authentication: Proving Who You Are

Encryption protects data in transit and at rest, but the system must still decide who may open the session. **Authentication** is the verification of a claimed identity. It relies on three families of factors:

- **Something you know**: a password, a PIN (your MoMo PIN, the PIN of your bank card).
- **Something you have**: a physical token, a bank card, a **SIM card** that receives a one-time code (OTP) by SMS.
- **Something you are**: **biometrics** — fingerprint, face or iris recognition, as on modern smartphones.

DEFINITION **Two-factor authentication (2FA)**

Two-factor authentication combines two factors of different families, so that stealing one is not enough. Example: a banking app asks for your password (something you know) and an OTP sent to your SIM (something you have). A thief who knows your password but does not have your phone cannot log in.

WARNING **Exam tip — know one concrete example of each factor**

In the GCE examination you may be asked to give an example of each authentication factor from daily life. Safe Cameroonian answers: PIN of a MoMo account (know), SIM card receiving an OTP or a bank token (have), fingerprint unlocking a phone (are). Do not confuse "two passwords" with 2FA: two factors of the same family is not two-factor authentication.

4.5 Access Control: Who May Do What

Once a user is authenticated, **access control** decides which operations he may perform on which resources. The building blocks are:

- **User accounts and groups**: each person has an individual account (for accountability); accounts are gathered into groups or **roles** (administrators, teachers, students).
- **Access rights**: typically read (r), write/modify (w), execute (x) and delete.
- **Access control list (ACL)**: for each resource, the list of users/groups and their rights.
- **Role-based access control (RBAC)**: rights are attached to roles, and users receive roles. When a new teacher is hired, giving him the "teacher" role instantly gives the correct rights — simpler and less error-prone than editing every file.

A central principle is **least privilege**: each user receives the minimum rights needed for his task, and nothing more. A student needs to read his own report card, never to write in the marks file.

Users / roles	Marks file	Report cards	User accounts
Administrator	r, w, x, delete	r, w, x, delete	r, w, x, delete
Teacher	r, w (enter marks)	r	none
Student	none	r (own card only)	none

An access-control matrix for a school results system: rows are roles, columns are resources, cells are the granted rights (r = read, w = write, x = execute). Note the least-privilege principle for students.

METHOD **Designing an access-control policy**

1. Identify all the users of the system and all the resources to protect.
2. Group users by role (director, teacher, student, bursar).
3. Grant each role the rights it strictly needs — apply least privilege.
4. Record the rights in an access-control matrix or ACLs, and implement them in the system.
5. Log every access (who, what, when) in an **audit log**, and review the logs and the rights regularly.

Good password policy. Authentication is only as strong as its passwords. A sound policy requires: sufficient length (at least 8–12 characters), complexity (mix of upper/lowercase, digits, symbols; no names or birthdays), regular renewal, no sharing and no reuse across systems; **account lockout** after a few failed attempts (to block guessing); and **audit logs** to trace who did what.

WARNING **Common mistake: encryption alone is not enough**

Encryption protects confidentiality, but if an attacker steals or guesses a password, he logs in as a legitimate user and the system happily decrypts everything for him. Encryption must always be combined with strong authentication (good passwords, 2FA) and access control (least privilege). Similarly, do not confuse hashing with encryption: encryption is reversible with the key; hashing is one-way.

WORKED EXAMPLE 4 **Choosing protections for an online results portal**

The GCE Board publishes results online. (a) Which mechanism guarantees that the connection between a candidate's browser and the server is confidential? (b) How can the server store candidates' passwords safely? (c) A candidate must not be able to modify results: which two mechanisms enforce this? (d) Why is 2FA recommended for the administrators' accounts?

SOLUTION

(a) HTTPS: the server presents a certificate signed by a certification authority; asymmetric encryption authenticates the server and exchanges a symmetric session key that encrypts the traffic. (b) Store only the hashes of the passwords: at login, the typed password is hashed and compared with the stored hash; stealing the database does not reveal the passwords, since hashing is one-way. (c) Authentication (each user logs in, ideally with 2FA) and access control with least privilege: candidates' accounts receive read-only rights on their own results, so even a logged-in candidate cannot write. (d) Administrators hold powerful rights; if an administrator's password is stolen, the second factor (e.g. an OTP on his phone) still blocks the attacker, protecting the integrity of all results.

EXERCISE 4 **Securing a hospital records system**

A hospital in Yaoundé computerises its patient records. (1) Give one reason of confidentiality, one of integrity and one of availability for protecting these records. (2) Should patient records be encrypted with a symmetric or an asymmetric algorithm for storage? Justify. (3) Doctors must read and write records, receptionists only read them, patients have no access. Draw the access-control matrix. (4) Propose a two-factor authentication scheme for doctors logging in from home.

SOLUTION **Exercise 1**

(1) Confidentiality: illness is private, only care staff may read the file. Integrity: prescriptions and dosages must not be altered. Availability: a doctor must access the file during an emergency at night. (2) Symmetric encryption (e.g. AES): storage encryption is done and undone by the same system, so one secret key suffices and symmetric encryption is fast for large volumes; asymmetric encryption serves for key exchange and signatures, not bulk storage. (3) Matrix: Doctors — records: r, w; Receptionists — records: r; Patients — records: none. (4) Password (something you know) plus an OTP sent to the doctor's phone or generated by a token (something you have); optionally a fingerprint on the hospital laptop as the second factor.

KEY POINTS **Key points**

- Data protection targets confidentiality, integrity, availability; personal data (results, health, money) is protected by Cameroonian law and international principles.
- Encryption: plaintext + key → ciphertext. Symmetric (one shared key, fast, key-distribution problem) vs asymmetric (public/private pair; what the public key encrypts only the private key decrypts).
- Hashing is one-way: used for password storage and file integrity. A digital signature = hash encrypted with the private key; it gives authenticity, integrity and non-repudiation; certificates and CAs bind public keys to identities (HTTPS padlock).
- Authentication factors: know (PIN), have (SIM/OTP, token), are (fingerprint); 2FA combines two families.
- Access control: accounts, roles, rights (r/w/x/delete), ACLs, RBAC, least privilege, audit logs, strong password policy with lockout.

5 DATA VALIDATION, VERIFICATION AND INTEGRATION

In the previous section we saw how access control protects data once it is stored: passwords, user rights, encryption and audit trails all guard the database against unauthorised eyes. But there is an earlier, quieter battle that every information system must win: the battle at the point of entry. If wrong, incomplete or malicious data is allowed into the system, then even the best firewall and the strongest password policy are useless — the organisation will simply be protecting rubbish. In this final section we study how systems check data as it arrives (**validation**), how they confirm that it was copied faithfully (**verification**), and how all the ideas of this chapter — intranets, VPNs, security policies, access control and data checking — combine into one coherent solution.

5.1 Validation versus Verification: the Classic Distinction

Imagine a clerk at a school in Bamenda typing students' dates of birth into a registration database. Two very different things can go wrong:

- The student wrote "32/13/2010" on the paper form. This date is impossible — no month has 32 days and there is no 13th month. The computer can refuse it immediately.
- The student was born on 12/05/2008, but the clerk typed 12/05/2009. This date is perfectly plausible — it looks fine, passes every automatic check, yet it is simply wrong.

These two situations correspond to the two great ideas of this lesson.

DEFINITION **Validation and Verification**

Validation is the automatic checking, performed by the computer at the moment of entry, that data is reasonable, plausible and acceptable — that it obeys the rules defined for that field (presence, type, range, format, length, consistency).

Verification is the checking that data has been copied or entered correctly — that what is in the computer matches the original source (the paper form, the identity card, the spoken order). It is usually done by a human or by entering the data twice.

KEY POINTS **The exam distinction in one sentence**

Validation asks: "Is this data sensible?" Verification asks: "Is this data the same as the original?" Validation is done by the computer; verification is usually done by the user. Neither alone is enough — you need both.

5.2 Validation Techniques

A well-designed input screen applies a battery of checks to every field. Here are the standard techniques you must know by name for the GCE.

DEFINITION **The standard validation checks**

- **Presence check**: the field must not be left empty (e.g. a student record must have a name).
- **Data-type check**: the entry must be of the correct type — a number where a number is expected, a date where a date is expected (typing "abc" into the fees field is rejected).
- **Range check**: a numeric (or date) value must lie between stated limits (e.g. term mark between 0 and 20).
- **Format check**: the entry must follow a fixed pattern (e.g. a date as DD/MM/YYYY, a Cameroonian phone number as 6 followed by 8 digits).
- **Length check**: the entry must have an exact or maximum number of characters (e.g. a phone number of exactly 9 digits).
- **Check digit**: an extra digit calculated from the others, used to detect typing errors in codes (developed below).
- **Consistency (cross-field) check**: two or more fields must agree with each other (e.g. if "gender = F" then the title cannot be "Mr"; the date of birth must be consistent with the class enrolled).

METHOD **Choosing the right check for each field**

For every field on a form, ask yourself the following questions, in order:

1. Must it be present? If yes → presence check.
2. What type should it be? Number, date, text → data-type check.
3. Are there limits? Minimum/maximum value → range check.
4. Is there a fixed pattern or size? → format check and/or length check.
5. Does it carry a code? → check digit.
6. Must it agree with another field? → consistency check.

A single field usually needs several of these checks together.

EXEMPLE **Validating a student registration form**

A school in Yaoundé designs an online registration form. The checks chosen for each field are:

Field	Validation checks applied
Full name	Presence check; data-type check (letters only)
Date of birth	Presence; format check DD/MM/YYYY; range check (must be a plausible past date, e.g. between 1995 and today)
Class	Presence; consistency check with date of birth (a 6-year-old cannot be in Upper Sixth)
Phone number	Presence; data-type (digits); length check (exactly 9 digits); format check (must begin with 6)
Fees paid	Data-type (numeric); range check (0 to the official annual fee)

WARNING **Exam tip — be precise**

In "design a form" questions, never write a vague phrase such as "validate the data". The examiner wants the exact check for each field: write "range check 0–20 for the term mark" or "length check of 9 digits for the phone number". Precision earns marks.

5.3 Verification Techniques

Verification catches the errors that validation cannot see — the plausible but wrong values. Three techniques are expected at GCE level:

- **Double entry**: the same data is typed twice (often by two different operators) and the computer compares the two versions. Any difference is flagged for correction. Banks and examination boards use this for critical figures.
- **Proofreading / visual check**: the user reads what is on the screen and compares it carefully with the source document before confirming. Simple, cheap, but dependent on human attention.
- **Confirmation messages**: the system sends back a summary for the user to approve. After a mobile money transfer with MTN MoMo or Orange Money, the SMS recap (amount, recipient, reference) lets the sender verify that the transaction was recorded as intended.

WARNING **The most common mistake**

Candidates often write that validation "makes sure the data is correct". This is false. Validation only guarantees that data is reasonable. If a student is 26 but the clerk types 25, every validation check passes — only verification (comparing with the birth certificate) or a later audit can catch it.

5.4 Check Digits: Catching Typing Errors Automatically

Long codes — bank account numbers, national ID numbers, product barcodes, examination candidate numbers — are easy to mistype. The clever solution is to add one extra digit, the **check digit**, which is calculated from the other digits. When the code is typed, the computer recalculates the check digit; if it does not match, the code must contain an error.

PROPERTY **Principle of a check digit**

A weight is assigned to each position of the code. Each digit is multiplied by its weight, the products are summed, and the sum is reduced modulo some number (often 10 or 11). The result (or its complement) is appended as the check digit. Because each position has a different weight, swapping two adjacent digits — the most common typing slip — changes the sum and is detected.

WORKED EXAMPLE 5 **Computing a check digit**

A school assigns each candidate a 4-digit code, to which a check digit is added using weights 4, 3, 2, 1 (left to right), modulo 11. The check digit is the remainder of the weighted sum divided by 11. Compute the check digit for the code 5273.

SOLUTION

Step 1 — multiply each digit by its weight:

$5 \times 4 = 20$ $2 \times 3 = 6$ $7 \times 2 = 14$ $3 \times 1 = 3$

Step 2 — sum the products:

$$20 + 6 + 14 + 3 = 43$$

Step 3 — reduce modulo 11:

$$43 = 3 \times 11 + 10 \quad \Rightarrow \quad 43 \bmod 11 = 10$$

Step 4 — append the check digit. The full code becomes 5273-10 (some systems write X for 10).

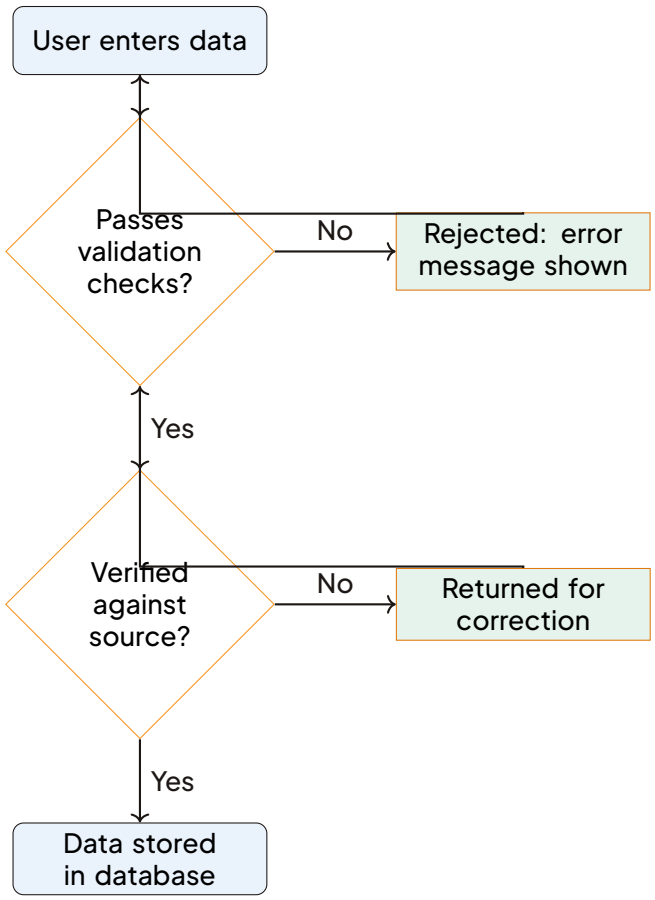
Why it works: if a clerk types 5273 as 5723 (two digits swapped), the weighted sum becomes $20 + 21 + 4 + 3 = 48$, and $48 \bmod 11 = 4 \neq 10$: the error is detected instantly.

KEY POINTS **Key idea**

A check digit lets the computer detect transcription errors automatically, with no human comparison needed. You must be able to compute one: multiply by the weights, sum, take the modulo, append.

5.5 The Data Entry Pipeline

The diagram below summarises the complete journey of a piece of data, from the user's keyboard to the database.



The data entry pipeline: validation filters implausible data, verification filters miscopied data, and only then is the data stored.

5.6 Validation as a Security Defence

Validation is not only about typing mistakes — it is also a front-line security weapon. Attackers frequently abuse input fields by typing malformed or malicious data instead of ordinary values. A classic example is **SQL injection**: instead of a name, the attacker types a fragment of database command such as `' OR 1=1 --` into a login field, hoping the system will execute it and reveal the whole database. Strict validation — rejecting unexpected characters, enforcing length and format — blocks most of these attacks before they reach the database. In Cameroon, bodies such as ANTIC encourage exactly this kind of "secure by design" thinking in national e-government services. (This link between validation and security is a useful extension that can earn extra credit in GCE essays.)

5.7 Integration: Building One Coherent Solution

This chapter has equipped you with five families of tools. A real organisation does not use them separately — it weaves them into a single architecture. Consider how a Cameroonian microfinance institution with branches in Douala, Bafoussam and Ngaoundéré might proceed:

1. **Intranet:** an internal network hosts the client database, the loan-management application and internal messaging, accessible only to staff.
2. **Extranet:** selected partners (e.g. an external auditor or a partner bank) are given controlled access to a limited part of the intranet — never the whole system.
3. **VPN:** staff travelling between branches connect through an encrypted VPN tunnel over the public CAMTEL or mobile networks, so intercepted traffic is unreadable.
4. **Security policy and access control:** a written policy defines strong passwords, user roles (cashier, manager, administrator) with least-privilege rights, regular backups and audit logs.
5. **Validation and verification:** every data-entry screen applies presence, type, range, format and consistency checks; account numbers carry check digits; large transactions are confirmed by SMS recap to the client.

Each layer covers the weaknesses of the others: the VPN protects data in transit, access control protects it at rest, and validation protects its quality at entry. Remove one layer and the whole system becomes vulnerable.

EXERCISE 5 **Designing checks for a cooperative**

A farmers' cooperative in the North-West Region registers members online with the fields: member ID (5 digits), name, village, telephone, and annual contribution (between 5 000 and 50 000 FCFA). For each field, state the exact validation check(s) you would apply, and name one verification technique suitable for the contribution amount.

SOLUTION **Exercise 1**

Member ID: presence check; data-type check (numeric); length check (exactly 5 digits); ideally a check digit appended. Name: presence check; data-type check (letters). Village: presence check (possibly a lookup against a list of villages). Telephone: presence; data-type (digits); length check (9 digits); format check (begins with 6). Contribution: data-type (numeric); range check 5 000–50 000 FCFA. Verification: double entry of the amount by two operators, or an SMS/paper receipt sent to the member for confirmation.

DID YOU KNOW? **Did you know?**

Every barcode scanned in a Cameroonian supermarket carries a check digit computed with weights alternating between 1 and 3, modulo 10. That is why the till beeps an error instantly when a cashier keys a barcode by hand and slips on one digit — the arithmetic simply no longer adds up.

KEY POINTS **Chapter synthesis**

Validation makes data reasonable; verification makes it faithful; check digits automate the detection of typing errors; and none of it works in isolation. The complete implementation of network security combines an intranet for internal work, an extranet for trusted partners, VPNs for safe remote access, a security policy with access control for stored data, and rigorous validation and verification at every point of entry.

6 INTEGRATION ACTIVITY

6.1 Aims of the activity

This integration activity closes the chapter on the **implementation of network security**. It mobilises, in one realistic project, all the competences developed in Lessons 21 to 25. By the end of the activity, you should be able to:

- distinguish and position an **intranet**, an **extranet** and **VPN** links on a network diagram;
- identify realistic **threats** to a small organisation and match each threat with an appropriate **countermeasure**;
- build an **access-control matrix** implementing the principle of least privilege;
- design a data-entry form protected by **validation** and **verification** techniques;
- justify technical choices orally, as an ICT consultant defending a solution before a board of directors.

KEY POINTS **Competence being assessed**

« Given a real organisation, analyse its security needs and propose a coherent, justified network-security solution covering architecture, threats, access control and data quality. »

6.2 Situation

EXPERIMENT **Case study: Sawa Microfinance SARL**

Sawa Microfinance SARL is a small microfinance institution. Its head office is in Douala (Bonanjo): 15 desktop PCs, one file-and-database server hosting the client savings and loans database, one printer, all connected to a switch and a router linked to the Internet through a CAMTEL fibre line. Its branch office in Bafoussam has 5 PCs connected to the Internet via a 4G router (MTN/Orange). The two sites must share the client database daily. Three additional needs have been expressed:

- the manager travels frequently (Yaoundé, Limbe) and must consult reports remotely from a laptop;
- field agents collect savings in markets (Marché Central, Mokolo) with laptops and enter transactions in the evening;
- the partner bank (a commercial bank in Douala) must be able to consult, read-only, a summary of loan guarantees — and nothing else.

Last month, an agent's laptop was stolen, a virus infected two PCs through a USB key, and

a power cut corrupted the database during a storm. The board has hired your group as ICT consultants to secure the whole system with a limited budget.

6.3 Tasks

Work in groups of four. Produce the four deliverables listed at the end.

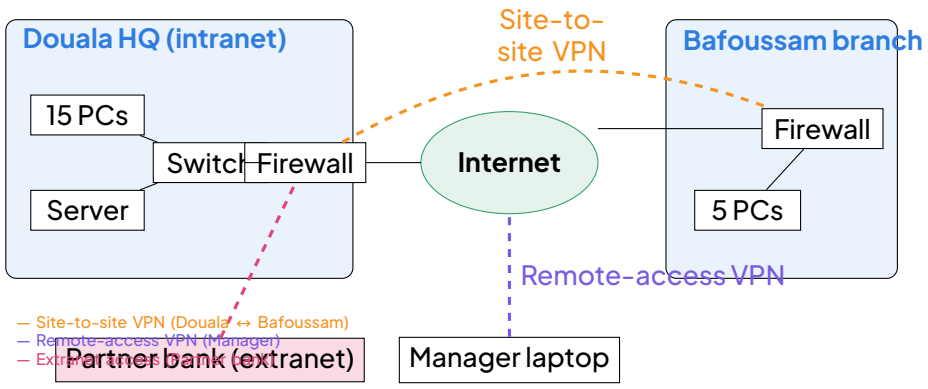
1. **Architecture.** Draw the complete network diagram of Sawa Microfinance. Show clearly: the two LANs, the intranet, the extranet zone reserved for the partner bank, a site-to-site VPN tunnel linking Douala and Bafoussam through the Internet, and a remote-access VPN for the manager. Place the firewall(s) and the server.
2. **Risk analysis.** List five threats the company faces (at least one physical, one human, one software-related). For each, state the asset endangered and propose one concrete countermeasure chosen from: firewall, antivirus, backups, staff training, UPS — justifying your choice in one sentence.
3. **Access control.** Build an access-control matrix for four roles — director, accountant, field agent, partner bank auditor — against four resources: client database (read), client database (write), financial reports, system settings. Apply the principle of least privilege.
4. **Data quality.** Sketch the client registration form (fields: client ID, full name, date of birth, telephone, savings amount, e-mail). Specify **one validation check per field** (presence, type, range, format, length, check digit…) and **one verification technique** for the whole form.
5. **Defence.** Present your solution in a 5-minute « board meeting »: one member presents the diagram, one the threats, one the access matrix, one the form. Be ready to answer the board's questions (e.g. « why a VPN and not just a password? »).

WARNING **Common traps**

Do not confuse the extranet (opened to a known partner) with the public Internet; do not give the field agent write access to financial reports « just in case »; a validation check never guarantees truth — a plausible but false telephone number passes a format check, hence the need for verification.

6.4 Model answer

1. Network architecture.



Secured architecture of Sawa Microfinance: two intranets linked by site-to-site VPN, remote-access VPN for mobile manager, extranet zone for partner bank.

The partner bank reaches only a read-only extranet service (e.g. a web portal or API), filtered by the Douala firewall; all inter-site and remote traffic is encrypted inside VPN tunnels (IPsec or SSL/TLS). The intranet at each site is the private LAN behind its firewall.

2. Threat–countermeasure table.

Threat	Asset endangered	Countermeasure (justified)
Virus / malware via USB keys	Workstations, database integrity	Antivirus on every machine, updated daily; blocks known malware signatures and heuristics
Power cuts and surges (storm)	Server hardware, database consistency	UPS (uninterruptible power supply) allows clean shutdown and protects against surges
Stolen agent laptop	Client data confidentiality	Staff training (awareness) + full-disk encryption and strong passwords; limits offline data access
Unauthorised intrusion from Internet	Entire network, all data	Firewall filtering all incoming traffic; default-deny policy with explicit allow rules only
Hardware failure, fire, flood	Database (single point of failure)	Regular automated backups kept off-site (e.g. weekly replica to Bafoussam server)

3. Access-control matrix (R = read, W = write, — = no access). The principle of **least privilege** grants each role only the permissions strictly necessary for its duties.

Role	Client DB (read)	Client DB (write)	Financial reports	System settings
Director	R	R	R	R
Accountant	R	R	R	—
Field agent	R (own clients only)	W (transactions only)	—	—
Bank auditor	R (summaries only, read-only view)	—	—	—

Notes: The director has full oversight; the accountant manages data and produces reports but cannot change system settings; the field agent can only view his own clients and record transactions; the bank auditor sees only aggregated guarantee summaries via the extranet portal — no direct database access.

4. Client registration form — validation and verification.

Field	Validation check (automatic, at entry)
Client ID	Format check: pattern `SM-` followed by 4 digits; last digit is a check digit (modulo 11)
Full name	Presence check (non-empty); character check: letters, spaces, hyphens only
Date of birth	Type check (valid calendar date); range check: age ≥ 18 years (adult)
Telephone	Length check: exactly 9 digits; format check: starts with 6 (Cameroon mobile: 6XX XXX XXX)
Savings amount	Type check (numeric, two decimals max); range check: 500 ≤ amount ≤ 5 000 000 FCFA
E-mail	Format check: contains exactly one "@" and a valid domain suffix (e.g. .cm, .com)

Verification technique (human, after entry): The completed form is re-displayed to the agent for visual proofreading before saving (screen verification), and the Client ID field requires double entry (entered twice) to catch transcription errors. Optionally, the agent reads back the telephone number to the client for oral confirmation.

KEY POINTS **Validation vs. Verification**

Validation = automatic checks at input time ("Is the data well-formed?"). Verification = human or cross-check procedures to ensure data corresponds to reality ("Is it the right data?"). Both are required for data quality.

5. Board defence — key arguments (5 minutes).

- **Architecture:** The site-to-site VPN creates an encrypted tunnel over the public Internet, so the Douala and Bafoussam LANs behave as one secure intranet. The remote-access VPN gives the manager the same protection from any location. The extranet is a demilitarised

zone (DMZ) exposing only a read-only service to the partner bank — the internal network remains invisible.

- **Threats:** Each identified risk is mitigated by a specific, cost-effective control: antivirus (software), UPS (physical), training (human), firewall (network), backups (disaster recovery). Defence in depth: if one layer fails, others remain.
- **Access control:** Least privilege limits the blast radius. Even if a field agent's credentials are stolen, the thief cannot read financial reports, modify system settings, or access other agents' clients.
- **Data quality:** Validation prevents garbage entering the database (which would corrupt loan decisions); verification catches plausible but wrong data (e.g. a valid-format but incorrect phone number).
- **Budget:** All solutions use standard, low-cost technologies (IPsec VPN on existing routers, open-source antivirus, scheduled backups to the branch server, built-in OS disk encryption).

EXERCISE 6 **Extension**

The board asks whether the stolen laptop could have been used to empty client accounts. Using your access matrix and the concept of authentication, explain in five lines why the thief could not, and propose one extra measure (e.g. two-factor authentication).

SOLUTION **Extension exercise**

The thief possesses the machine but not the agent's credentials: authentication (login + password) blocks access to the application, and even a valid agent account only grants write access to transactions of his own clients — not to reports, settings, or other clients' accounts (least privilege). Full-disk encryption prevents reading cached data offline. Adding two-factor authentication (password + one-time code sent by SMS or authenticator app) means that even a stolen password is useless without the agent's second factor, which strongly reduces the risk.

DID YOU KNOW? **Cameroon context**

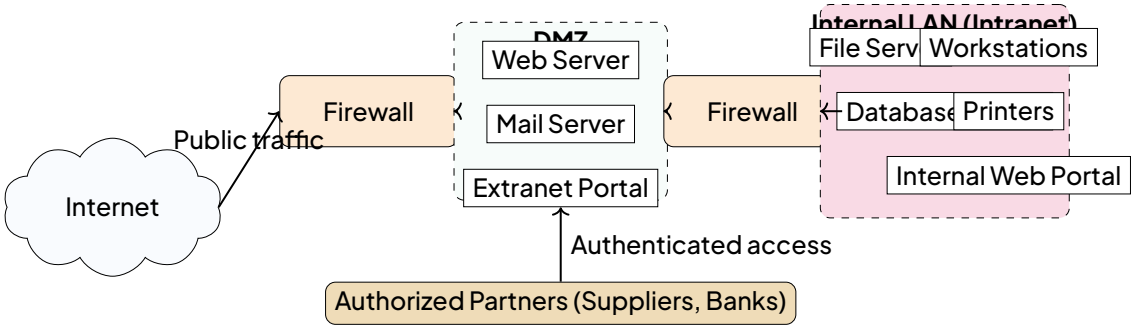
In Cameroon, microfinance institutions are regulated by COBAC (Commission Bancaire de l'Afrique Centrale) and must comply with data-protection guidelines from ANTIC (Agence Nationale des Technologies de l'Information et de la Communication). The use of VPNs, firewalls, and regular backups aligns with ANTIC's Guide de sécurité des systèmes d'information. Mobile money integration (MTN MoMo, Orange Money) often requires API access over secured channels — similar to the partner-bank extranet shown here.

7 METHODS AND WORKED EXAMPLES

8 IMPLEMENTATION OF NETWORK SECURITY

9 INTRANETS AND EXTRANETS

9.1 Designing an Intranet/Extranet Architecture for an Organisation



Legend:
— Internet (untrusted)
— Firewalls (perimeter defence)
— DMZ (public/extranet services)
— Intranet (private, trusted)

Typical network architecture showing Intranet, Extranet (DMZ) and Internet zones.

METHOD **Choosing between Intranet, Extranet and public Internet services**

When a GCE question describes an organisation's communication needs, proceed as follows:

1. Identify the users of the service: only employees (internal), employees plus trusted partners (suppliers, banks, ministries), or the general public.
2. Match users to the network type: internal only ⇒ **intranet**; internal plus authorised external partners ⇒ **extranet**; everyone ⇒ public website on the Internet.
3. Identify the protection mechanism: an intranet is protected by the organisation's **firewall**; an extranet is typically implemented as a controlled opening of the intranet

(DMZ servers, authenticated accounts) or through a **VPN**.

4. List concrete services to justify the choice: document sharing, internal messaging, leave-request forms, catalogue access for partners, etc.
5. Conclude with the benefit: cost reduction, faster information flow, better collaboration, controlled confidentiality.

Reflex: always name who accesses what, and through which barrier (firewall, password, VPN tunnel).

KEY POINTS **Key Distinctions**

- Intranet: Private TCP/IP network using web technologies, accessible only to authenticated internal users. Protected by firewall. Example: staff portal, HR forms, internal wiki.
- Extranet: Controlled extension of the intranet to specific external partners. Requires strong authentication (accounts, certificates, VPN). Hosted in a DMZ. Example: supplier stock lookup, bank statement download.
- Public Website: Accessible to anyone on the Internet. No access to internal data. Hosted in DMZ or at ISP.

WORKED EXAMPLE 6 **Network plan for a Douala import company**

A company in Douala has 60 employees in three buildings. Management wants: (a) an internal platform where staff share documents and fill in leave forms; (b) its five main suppliers in Bonaberi to consult stock levels of the products they supply, but nothing else; (c) a public page advertising the company. For each need, state the type of network service required and justify your answer.

SOLUTION

Need (a) – internal platform. Users are employees only, so this is an **intranet**: a private TCP/IP network inside the company, using web technologies (browser + internal web server) but unreachable from the Internet because the company's firewall blocks incoming connections. Services: shared folders, internal web portal, electronic leave forms, internal e-mail.
Need (b) – supplier access to stock levels. Users are employees plus a restricted group of trusted external partners. This is an **extranet**: a controlled extension of the intranet. Implementation: the stock server is placed in a **DMZ** (a buffer zone between the internal network and the Internet), each supplier receives a personal account and password, and

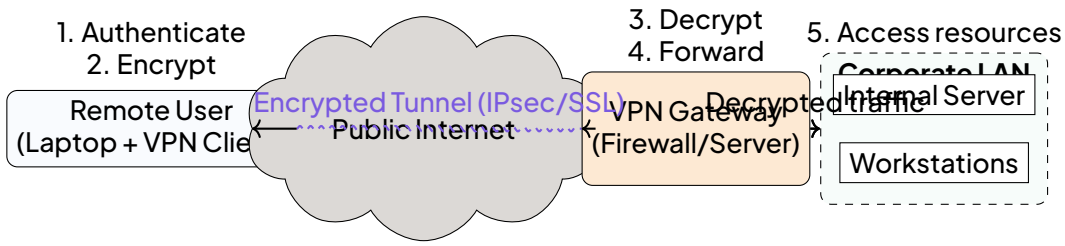
access rights are limited to the stock database of their own products. Alternatively, suppliers connect through a VPN tunnel.
Need (c) – advertising page. Users are the general public, so this is an ordinary **public website** hosted on a web server visible from the Internet (hosted at an ISP or in the DMZ). No company internal data is placed on it.
Summary table:

Need	Users	Solution
(a) Internal platform	Employees only	Intranet behind the firewall
(b) Stock consultation	Employees + 5 suppliers	Extranet (DMZ server + accounts, or VPN)
(c) Advertising	General public	Public website on the Internet

Common mistake to avoid: do not say "extranet = the company's website". An extranet is private and authenticated; a website is public.

10 VIRTUAL PRIVATE NETWORKS (VPNS) AND PRIVACY

10.1 Explaining and Choosing a VPN Solution



Remote-access VPN: encrypted tunnel across the public Internet.

METHOD **Analysing a VPN scenario**

1. Spot the problem: a remote user (teleworker, travelling salesman, branch office) must reach internal resources over the insecure public Internet.
2. State the risk: data crossing the Internet in clear can be intercepted (sniffing), modified or spoofed. Privacy is violated.

3. Give the VPN principle: create an encrypted **tunnel** between the remote machine and the organisation's VPN gateway. Data is encrypted at the sender, travels as unreadable ciphertext, and is decrypted at the gateway. The remote machine receives an internal IP address and behaves as if it were inside the intranet.
4. Name the two VPN types: **remote-access VPN** (one user → company) and **site-to-site VPN** (two branch networks permanently linked).
5. Quote protocols when asked: IPsec (network layer), SSL/TLS (application layer, often used for clientless VPNs), L2TP/IPsec, PPTP (older, insecure), OpenVPN, WireGuard (modern, high performance).
6. Mention limits honestly: a VPN protects data in transit; it does not remove viruses, does not secure a compromised endpoint, and the VPN provider must be trustworthy. Privacy depends on the provider's logging policy.

WORKED EXAMPLE 7 **Teleworking accountant in Yaoundé**

The accountant of a Yaoundé microfinance institution must work from home twice a week and use the accounting software installed on the office server. The director proposes to "just open the server on the Internet". (1) Explain why this is dangerous. (2) Propose a better solution and describe, step by step, what happens when the accountant connects. (3) Name the type of VPN involved.

SOLUTION

(1) Danger of direct exposure. Opening the server directly on the Internet means its ports are visible to the whole world. Attackers can scan it, attempt password guessing (brute force), exploit unpatched software flaws, and intercept the unencrypted traffic – including confidential client account data. For a financial institution this could mean theft of funds and a breach of data-protection obligations (Law No. 2010/012 on cybersecurity in Cameroon).
(2) Better solution: a remote-access VPN.

1. A VPN gateway (server or firewall with VPN function) is installed at the office; it is the only machine visible from the Internet.
2. The accountant launches VPN client software at home and authenticates (username + password, ideally plus a one-time code – two-factor authentication).
3. An encrypted tunnel is negotiated (e.g. IPsec or SSL/TLS): both ends agree on session keys.
4. The gateway assigns the home PC an internal IP address of the office network.
5. The accounting software then communicates with the server exactly as if the PC were

in the office, but every packet crossing the Internet is ciphertext.

(3) Type. One remote user connecting to one site ⇒ **remote-access VPN**. (If the institution later links its Yaoundé and Bafoussam branches permanently, that would be a **site-to-site VPN**.)
Exam tip: always mention authentication and encryption – these are the two pillars that make a VPN secure.

DID YOU KNOW? **VPN in Cameroon**

Many Cameroonian businesses use VPNs to connect branches (e.g., Douala headquarters to Yaoundé, Bafoussam, Bamenda agencies) over CAMTEL's fibre or MTN/Orange 4G links. ANTIC (Agence Nationale des Technologies de l'Information et de la Communication) recommends IPsec or SSL VPNs for securing administrative data exchanges in e-government projects. Mobile money platforms (MTN MoMo, Orange Money) use VPN-like encrypted tunnels between agents' POS terminals and central servers.

11 COMPUTER AND NETWORK SECURITY: THREATS AND COUNTERMEASURES

11.1 Identifying Threats and Matching Countermeasures

METHOD **Threat → countermeasure analysis**

In exam scenarios, build a two-column reasoning:

1. Classify the threat: malware (virus, worm, trojan, ransomware, spyware), human attack (phishing, social engineering, password attack), network attack (sniffing, spoofing, denial of service, man-in-the-middle), or physical threat (theft, fire, power cut).
2. State the security property at risk: **confidentiality**, **integrity**, **availability** (the CIA triad), sometimes authenticity and non-repudiation.
3. Propose a technical countermeasure: antivirus/anti-malware, firewall, encryption, strong authentication (2FA), backup, UPS, updates/patches, intrusion detection/prevention systems (IDS/IPS).
4. Add the human/organisational measure: user training, security policy, access badges, password rules, incident response plan. Examiners reward answers that combine both.

Reflex: one threat can need several layers of defence (“defence in depth”).

WORKED EXAMPLE 8 **Incident at a cybercafé-school in Bamenda**

A school in Bamenda notices the following events in one month: (a) a USB flash drive brought by a student infects three PCs with a virus; (b) the secretary receives an e-mail pretending to come from the bank and nearly types her password on a fake page; (c) during a storm, a power surge destroys the bursar’s hard disk and the fee records are lost. For each event, identify the threat, the security property affected, and propose at least two countermeasures.

SOLUTION

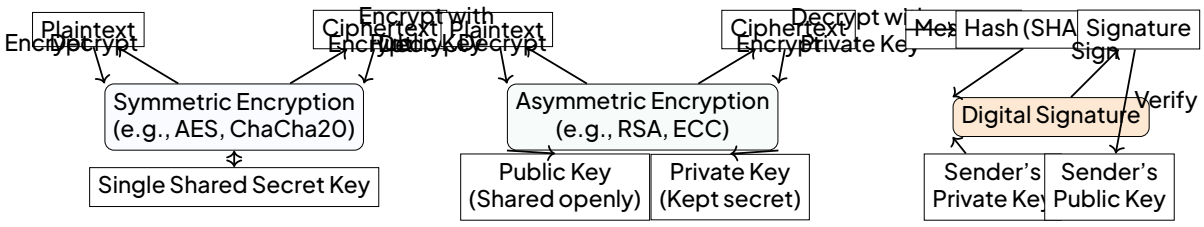
(a) USB virus. Threat: **malware** (virus propagating via removable media). Property at risk: integrity and availability of the systems. Countermeasures: install and update **antivirus** software on every PC; disable autorun from USB devices or scan every flash drive before use; restrict students’ accounts so they cannot install software; educate users about unknown media.
(b) Fake bank e-mail. Threat: **phishing** (a social-engineering attack). Property at risk: confidentiality of credentials, potentially leading to financial theft. Countermeasures: human – train staff never to follow links in unexpected e-mails and to check the sender’s address and the site’s URL/HTTPS certificate; technical – spam/anti-phishing filter on the mail server, two-factor authentication on the bank account so a stolen password alone is useless.
(c) Power surge destroying the disk. Threat: **physical/environmental** damage. Property at risk: availability and integrity of data. Countermeasures: connect equipment through a **UPS** (uninterruptible power supply) and surge protector; perform regular **backups** of fee records on an external disk or cloud storage kept in a different room; keep a spare disk/image for fast recovery.
Key idea: security is not only about hackers – hardware failure and human error are threats too, and backups are the last line of defence.

WARNING **Common Exam Traps**

- Confusing threat (potential cause of harm) with vulnerability (weakness) and risk (likelihood × impact).
- Listing only technical measures; always include user awareness/training.
- Saying “firewall stops viruses” – firewalls filter network traffic; antivirus scans files.
- Forgetting that encryption protects confidentiality, not integrity or availability (unless

combined with hashing/signatures).

11.2 Encrypting and Decrypting: Symmetric vs Asymmetric



Symmetric vs Asymmetric encryption and digital signature principle.

METHOD **Handling a cryptography question**

1. Define the goal: confidentiality (encryption), integrity (hashing), authenticity/non-repudiation (digital signature).
2. Symmetric encryption: one shared secret key encrypts and decrypts (e.g. AES, Caesar as a toy example). Fast, but the key must be transmitted safely – the **key distribution problem**.
3. Asymmetric encryption: each user has a **public key** (shared with everyone) and a **private key** (kept secret). To send a secret to Alice: encrypt with Alice's public key; only Alice's private key decrypts it.
4. Digital signature: the sender encrypts a hash of the message with his own private key; anyone can verify with his public key ⇒ proves origin and integrity.
5. For small numeric exercises (Caesar cipher): encryption is $C = (P + k) \bmod 26$, decryption $P = (C - k) \bmod 26$, with letters numbered $A = 0, \ldots, Z = 25$.

WORKED EXAMPLE 9 **Caesar cipher and key choice**

(1) Using a Caesar cipher with key $k = 5$, encrypt the word `EXAM`. (2) Decrypt the message `JSF` received with the same key. (3) A student says: "Since Caesar is too weak, let us use AES, and I will e-mail the secret key to my friend." Identify the weakness of this plan and propose a solution based on asymmetric cryptography.

SOLUTION

(1) Encryption, $k = 5$. Number the letters ($A = 0$): E= 4, X= 23, A= 0, M= 12.

$$E: (4 + 5) \bmod 26 = 9 \rightarrow J$$
$$X: (23 + 5) \bmod 26 = 28 \bmod 26 = 2 \rightarrow C$$
$$A: (0 + 5) \bmod 26 = 5 \rightarrow F$$
$$M: (12 + 5) \bmod 26 = 17 \rightarrow R$$

Ciphertext: `JCFR`.
(2) Decryption of `JSF`. J= 9, S= 18, F= 5.

$$J: (9 - 5) \bmod 26 = 4 \rightarrow E$$
$$S: (18 - 5) \bmod 26 = 13 \rightarrow N$$
$$F: (5 - 5) \bmod 26 = 0 \rightarrow A$$

Plaintext: `ENA`.
(3) Weakness and solution. AES is strong, but sending the secret key by ordinary e-mail exposes it to interception: anyone who reads the e-mail can decrypt everything. This is the **key distribution problem** of symmetric cryptography. Solution: the friend generates a public/private key pair and publishes the public key; the student encrypts the AES key with the friend's public key and e-mails it. Only the friend's private key can recover the AES key. (This hybrid scheme – asymmetric to exchange a session key, symmetric for bulk data – is exactly what TLS/HTTPS does.)

12 DATA PROTECTION AND ACCESS CONTROL

12.1 Applying Access Control: Authentication, Authorisation and User Rights

METHOD **Designing an access-control policy**

1. List the resources to protect (files, databases, printers, applications).
2. List the user groups (roles), not individuals: e.g. administrators, teachers, students, guests.
3. Choose authentication: something you know (password, PIN), something you have (badge, token, phone), something you are (fingerprint, face). Combining two factors (**2FA**) is much stronger.

4. Assign authorisations (rights) per group using the **principle of least privilege**: each user gets the minimum rights needed for the job. Typical rights: read (R), write (W), execute (X), delete, no access.
5. Enforce and audit: strong password rules (length, expiry), account lockout after failed attempts, log files recording who did what.

Reflex: distinguish clearly authentication (proving who you are) from authorisation (what you are allowed to do).

KEY POINTS **Access Control Models**

- DAC (Discretionary Access Control): Owner decides (e.g., Windows file permissions).
- MAC (Mandatory Access Control): System enforces labels (e.g., military classifications).
- RBAC (Role-Based Access Control): Rights assigned to roles, users assigned to roles (most common in enterprises).
- ABAC (Attribute-Based Access Control): Decisions based on attributes (time, location, device).

WORKED EXAMPLE 10 **Rights matrix for a school server**

A college network has a shared folder `MARKS` containing students' results, a folder `COURSES` with lesson notes, and the administration database. Users: the principal, teachers, students. Build an access-rights matrix applying least privilege, and justify two of your choices. State also one authentication improvement you recommend.

SOLUTION

Proposed matrix (R = read, W = write, – = no access):

Resource	Principal	Teachers	Students
`MARKS` (results)	R + W	R + W (own subjects)	R (own results only)
`COURSES` (notes)	R	R + W	R
Administration database	R + W	–	–

Justifications.

- Students on *`MARKS`*: read-only, and ideally filtered to each student's own record:

results are personal data; write access would let a student alter marks (integrity breach).

- Teachers on the administration database: no access – fees and payroll are not needed for teaching (least privilege). This limits damage if a teacher's password is stolen.

Authentication improvement. Enforce strong passwords (minimum length, mixed characters, regular change) and add a second factor for the principal and bursar accounts (e.g. a code sent to a phone), because these accounts have the most sensitive rights. Add account lockout after, say, 5 failed attempts to defeat brute-force guessing, and keep log files to audit access to `MARKS`.

13 DATA VALIDATION, VERIFICATION AND INTEGRATION

13.1 Applying Data Validation and Verification Techniques

METHOD **Choosing the right validation/verification check**

1. Distinguish the two families: **validation** = automatic checks performed by the program at data entry (is the data plausible and well-formed?); **verification** = checking that data was copied/transmitted correctly (matches the source).
2. Know the validation checks: presence check (field not empty), data-type check (numeric, date), format check (e.g. a phone number pattern), range check (marks between 0 and 20), length check, check digit (for account/ID numbers), consistency (cross-field) check.
3. Know the verification techniques: double entry (type twice, compare), visual/proof checking against the source document, echo-back/parity and checksums during transmission.
4. Exam reflex: quote the name of the check, then apply it to the field in the question with a concrete valid/invalid example.
5. Remember the limit: validation cannot detect a value that is plausible but wrong (typing 15 instead of 16 passes a range check 0–20).

WORKED EXAMPLE 11 **Validating a GCE registration form**

A school enters candidates for the GCE using a form with the fields: `CandidateID` (8 dig-

its, the last being a check digit), `Name`, `DateOfBirth`, `Subject1_Mark` (0–20), `CentreNumber`. For each field, propose an appropriate validation check with an example of rejected data. Then explain how the school can verify the entered marks before sending the file to the GCE Board.

SOLUTION

Validation per field:

Field	Check(s)	Rejected example
`CandidateID`	Format (8 digits) + **check digit**	`1234567A`; wrong check digit
`Name`	Presence + type (letters only)	empty field; `Ng0n0`
`DateOfBirth`	Type (valid date) + range	`31/02/2009`; year 1890
`Subject1_Mark`	Type (numeric) + range $0 \le m \le 20$	`24`; `abc`
`CentreNumber`	Presence + lookup in centre list	number not in the official list

Verification of marks before sending:

- Double entry: two different operators type each mark from the mark sheets; the program compares the two versions and flags any mismatch for correction.
- Visual/proof check: print the entered list and read it aloud against the original signed mark sheets, ticking each line.
- Transmission check: when the file is sent to the Board, a checksum/hash accompanies it so the receiver can detect any corruption during transfer.

Warning: even after all this, a mark of 15 typed instead of 16 survives every check – only proofreading against the source catches it. That is why verification complements validation.

13.2 Integration Activity: Securing a Complete Small Network

METHOD **Writing a full security plan (synthesis skill)**

For a long GCE "scenario" question, structure the answer in layers:

1. Perimeter: firewall between the LAN and the Internet; DMZ for public servers; VPN for remote access.
2. Network services: intranet for staff, extranet for partners, public website.
3. Hosts: antivirus, operating-system updates, least-privilege user accounts.
4. Data: access-rights matrix, encryption of sensitive traffic (HTTPS/VPN), backup plan

(frequency, off-site copy).

5. Data quality: validation checks in entry forms, verification procedures.

6. People: security policy, training against phishing, password discipline.

Present the answer as a short report with headings – this is what integration questions expect.

WORKED EXAMPLE 12 **Case study: securing a cooperative in Bafoussam**

A farmers' cooperative in Bafoussam has 20 staff PCs on a LAN, a server with the members' database (names, contributions, mobile-money numbers), and a website. The manager wants: staff file sharing, remote access for the auditor in Douala, online contribution statements for members, and protection against data loss and fraud. Produce a security plan covering: network architecture, remote access, access control, data protection, and data entry quality.

SOLUTION

1. Network architecture. Install a **firewall** between the LAN and the CAMTEL/ISP link. Place the public website and the members' statement server in a **DMZ** so that even if they are compromised, the internal LAN and the members' database stay protected. Staff file sharing runs on the **intranet** (internal web portal + shared folders), unreachable from outside.
2. Remote access for the auditor. Configure a **remote-access VPN** on the firewall. The auditor authenticates (password + one-time code on his phone), receives an internal IP address, and reaches the accounting application through an encrypted tunnel. Never expose the database server directly on the Internet.
3. Access control. Create groups: administrator (full rights), accountants (read/write on contributions), staff (read only on shared documents), auditor (read only on accounts, time-limited account). Apply least privilege; members consulting their statements online authenticate and see only their own record (extranet-style service). Enforce strong passwords, lockout after failed attempts, and keep audit logs.
4. Data protection. Encrypt sensitive traffic (HTTPS for the member portal, VPN for the auditor). Back up the database daily to an external drive and keep a weekly copy off-site (protection against fire/theft). Install antivirus on all PCs and apply updates. Use a UPS against power cuts.
5. Data entry quality. The contribution form validates: presence of member ID, check digit on the ID, numeric type and range on amounts, valid date. Verification: contributions are entered from signed receipts, then a second staff member proof-checks a printout against the receipts weekly.

Conclusion. Security is achieved in layers: no single measure is sufficient, and the human layer (training, procedures) is as important as the technical one.

EXERCISE 7 **Practice: Design a secure network for a rural health centre**

A health centre in a rural area has 5 PCs, a local server with patient records, and a satellite Internet link. A doctor in Yaoundé needs to review records weekly. The centre also wants a public health-info page. Sketch the network architecture (firewall, DMZ, VPN), define an access-rights matrix for (nurse, doctor, admin, public), list validation checks for a patient admission form, and propose a backup strategy. (Answer in the next session.)

14 EXERCISES

14.1 I check my knowledge

KEY POINTS **Key concepts at a glance**

- Intranet: private network using Internet technologies (TCP/IP, HTTP, DNS) restricted to an organisation's members.
- Extranet: controlled extension of an intranet to authorised external partners (suppliers, customers, remote staff).
- VPN (Virtual Private Network): creates an encrypted tunnel over a public network to guarantee confidentiality and integrity of data in transit.
- CIA triad: Confidentiality, Integrity, Availability — the three pillars of information security.
- Validation checks that data conforms to specified rules before acceptance; verification ensures data has been copied or transcribed accurately (e.g. double entry, proofreading).
- Access control models: DAC (discretionary), MAC (mandatory), RBAC (role-based) — RBAC is preferred in organisations for manageability and least privilege.

EXERCISE 8 **Multiple choice questions**

For each question, choose the single correct answer.

1. An extranet is best described as:

   (a) a network reserved exclusively for the employees of one organisation;

   (b) an extension of an intranet opened to selected external partners under controlled access;

   (c) any public website hosted by a company;

   (d) a wireless network covering a whole city.

2. The main purpose of a VPN tunnel is to:

   (a) increase the speed of the Internet connection;

   (b) encrypt traffic so that it cannot be read on an untrusted network;

   (c) block all viruses on the user's computer;

(d) hide the existence of the destination server.

3. In the CIA triad, making sure that examination results are not modified by an unauthorised person protects:

   (a) confidentiality;

   (b) integrity;

   (c) availability;

   (d) authenticity.

4. A check digit appended to a candidate number is an example of:

   (a) data encryption;

   (b) data verification;

   (c) data validation;

   (d) data compression.

EXERCISE 9 **True or false — justify**

State whether each statement is true or false, and justify your answer in one or two sentences.

1. An intranet uses the same technologies (TCP/IP, web browsers) as the public Internet.
2. Once a VPN is established, the user is protected against phishing attacks.
3. Symmetric encryption uses two different keys, one public and one private.
4. The principle of least privilege means giving every user administrator rights so that work is never blocked.
5. Double data entry is a verification technique, not a validation technique.

EXERCISE 10 **Key definitions**

Define each of the following terms in one or two sentences, giving one concrete example for each:

1. intranet;
2. tunnelling protocol;
3. firewall;

4. access control list (ACL);
5. phishing.

EXEMPLE **Worked example: modulo-11 check digit**

Compute the check digit for centre number `11703` using weights 6, 5, 4, 3, 2 (left to right) and the rule check = 11 − (sum mod 11), with 11 → 0 and 10 → X.

$$\begin{aligned} \text{Sum} &= 1\times 6 + 1\times 5 + 7\times 4 + 0\times 3 + 3\times 2 \\ &= 6 + 5 + 28 + 0 + 6 = 45 \\ 45 \bmod 11 &= 1 \quad (11\times 4 = 44) \\ \text{Check} &= 11 - 1 = 10 \rightarrow \text{X} \end{aligned}$$

The complete centre number is `11703X`.

EXERCISE 11 **Direct calculations**

1. A school allocates centre numbers of 5 digits followed by a check digit computed with a modulo-11 weighted scheme (weights 6, 5, 4, 3, 2 applied from left to right; check = 11 − (sum mod 11), where a result of 11 is written 0 and 10 is written X). Compute the check digit of the centre number 11703.
2. A company's backup policy keeps one full backup every Friday and incremental backups on the other working days. If the server crashes on a Thursday morning, how many backup sets must be restored, and in which order?

14.2 I practise

EXERCISE 12 **Classifying network scenarios**

1. Define the terms intranet and extranet, highlighting the difference between them.
2. Classify each of the following three scenarios as intranet, extranet or public Internet, justifying each answer:

   (a) a school result portal accessible only to enrolled students with a login;

   (b) a bank's internal electronic mail system, reachable only from the bank's branches;

(c) a supplier of raw materials who consults, through a secured login, the stock levels of a factory in Douala.

METHOD **How a VPN protects a connection — step by step**

1. Authentication: the client proves its identity to the VPN server (password, certificate, token).
2. Key exchange: using a protocol like IKE (Internet Key Exchange), both ends agree on symmetric session keys.
3. Tunnel creation: a virtual network interface is created; all IP packets from the client are encapsulated in an encrypted payload (ESP in IPsec, or TLS records in OpenVPN).
4. Transit: the encrypted packets travel over the public network (cybercafé Wi-Fi, ISP). Any eavesdropper sees only ciphertext.
5. Decapsulation: the VPN server decrypts, verifies integrity, and forwards the original packets to the office LAN.
6. Return path: replies follow the reverse process.

EXERCISE 13 **Working from a cybercafé**

A civil servant on mission in Bamenda connects from a cybercafé to his office server in Yaoundé using a VPN.

1. Explain, step by step, how the VPN protects his connection from the cybercafé's network to the office.
2. Name two protocols that can be used to build the VPN tunnel.
3. State one limit of the protection offered by the VPN, and one additional precaution the worker should take.

WARNING **Common VPN misconceptions**

- A VPN does not protect against phishing — if the user enters credentials on a fake site, the VPN faithfully encrypts that traffic to the attacker.
- A VPN does not hide the fact that you are using a VPN from the local network administrator (they see encrypted traffic to the VPN server).

- Split tunnelling (routing only corporate traffic through the VPN) exposes other traffic to the local network.

EXERCISE 14 **Threats, CIA properties and countermeasures**

Copy and complete the following table. For each threat, indicate the main CIA property violated (confidentiality, integrity or availability) and propose one suitable countermeasure.

Threat	CIA property violated	Countermeasure
Ransomware encrypting the school's files		
Phishing SMS imitating a mobile money service		
Denial-of-service attack on a results website		
Theft of the server from the computer room		
Power cut during data entry		
Packet sniffing on an open Wi-Fi network		

DID YOU KNOW? **Cameroon context: ANTIC and cybersecurity**

The Agence Nationale des Technologies de l'Information et de la Communication (ANTIC) is Cameroon's regulatory body for cybersecurity. It operates the `CERT-CM` (Computer Emergency Response Team) which coordinates incident response, publishes alerts, and promotes best practices. Schools and businesses are encouraged to report security incidents to `cert@antic.cm`.

EXERCISE 15 **Symmetric, asymmetric encryption and digital signature**

1. Explain the key-distribution problem of symmetric encryption.
2. Show how asymmetric (public-key) encryption solves this problem.
3. A regional delegation sends an examination-results file to a school. Describe precisely how a digital signature allows the school to prove that the file really comes from the delegation and has not been altered, stating which keys are used at each step.

14.3 I prepare for the GCE

EXERCISE 16 **Access control in a hospital — structured question (10 marks)**

A hospital in Buea uses a computerised patient-record system with four roles: doctor, nurse, receptionist and administrator. The resources are: medical records, appointment schedule, billing data and system configuration.

1. Construct an access matrix giving, for each role and each resource, the appropriate right among read, write, execute or none. (4 marks)
2. Justify each of your choices using the principle of least privilege. (4 marks)
3. Explain why the hospital should prefer role-based access control over attaching rights to individual users. (2 marks)

EXERCISE 17 **Validating a GCE candidate registration form (10 marks)**

A computerised registration form for GCE candidates contains the following fields: candidate name, date of birth, centre number and list of subjects.

1. For each of the four fields, specify the exact validation check(s) to apply (presence, type, format, range, length, check digit, cross-field consistency), justifying each choice. (4 marks)
2. Describe one verification technique that can be applied when the forms are typed into the system, and explain what kind of error it detects that validation cannot. (2 marks)
3. Centre numbers are 5 digits followed by a check digit computed with a modulo-11 weighted scheme (weights 6, 5, 4, 3, 2 from left to right; check = 11 − (sum mod 11), with 11 written 0 and 10 written X). Compute the check digit of centre number 11703, then state whether the entered number 11704 can be valid. (4 marks)

EXERCISE 18 **Essay: publishing results online safely (20 marks)**

"A secondary school in Cameroon wants to publish end-of-year results online while protecting students' personal data."
Write a structured essay discussing the technical and organisational measures required. Your essay must:

1. explain how the results website should be exposed (public site, intranet or extranet) and justify the choice; (4 marks)
2. describe the role of HTTPS and, where relevant, of a VPN for the staff who update the results remotely; (4 marks)

3. propose an authentication and access-rights policy distinguishing students, teachers and the system administrator, referring to the principle of least privilege; (4 marks)
4. specify the data validation and verification techniques to apply when results are entered, and explain how integrity and availability of the data are guaranteed (backups, protection against common threats); (4 marks)
5. conclude by discussing the legal and ethical responsibility of the school regarding personal data. (4 marks)

15 SOLUTIONS TO THE EXERCISES

SOLUTION **Exercise 1 — Multiple choice questions**

1. Answer: (b) An **extranet** is a controlled extension of an organisation's **intranet** that allows secure access to specific resources by authorised external parties such as suppliers, customers, or remote employees. Option (a) describes an intranet, (c) a public website, and (d) a metropolitan area network (MAN).

2. Answer: (b) The core function of a **VPN** (Virtual Private Network) is to create an encrypted tunnel over an untrusted public network (like the Internet or a cybercafé Wi-Fi) so that data **confidentiality** and **integrity** are preserved. It does not inherently increase speed (a), block viruses on the endpoint (c), or hide the destination server's existence (d) — it hides the content of the traffic.

3. Answer: (b) **Integrity** ensures that data is not altered, deleted, or corrupted by unauthorised parties. Protecting examination results from unauthorised modification is a classic integrity requirement. **Confidentiality** (a) protects against unauthorised reading, **availability** (c) ensures access when needed, and **authenticity** (d) verifies the origin.

4. Answer: (c) A **check digit** is a **validation** technique: it uses a mathematical algorithm (modulo-11 here) to verify that the structure of the entered code conforms to the expected rule before the data is accepted. **Verification** (b) checks accurate transcription (e.g. double entry), **encryption** (a) hides meaning, and **compression** (d) reduces size.

SOLUTION **Exercise 2 — True or false — justify**

1. True. An **intranet** uses the exact same TCP/IP protocol suite, web servers (HTTP/HTTPS), DNS, and browsers as the public Internet. The difference is purely organisational: access is restricted to authenticated members of the organisation (e.g. via firewalls, private IP ranges, VPN).

2. False. A **VPN** encrypts the transport between the client and the VPN server. It does not inspect the content for malicious intent. If the user clicks a phishing link and enters credentials on a fake website, the VPN will faithfully encrypt that traffic and send it to the attacker. Phishing protection requires user awareness, email filtering, and anti-phishing toolbars.

3. False. **Symmetric encryption** uses a single shared secret key for both encryption and decryption. **Asymmetric encryption** (public-key encryption) uses a mathematically

linked key pair: a public key (distributed openly) and a private key (kept secret).

4. False. The **principle of least privilege** states that a user should be given the minimum access rights necessary to perform their duties — never administrator rights by default. Giving everyone admin rights maximises the attack surface and violates this principle.

5. True. **Double entry** (two independent operators typing the same data, with the system comparing the two versions) is a **verification** technique. It detects transcription errors (typos, omissions) that validation cannot catch because the erroneous data might still satisfy all validation rules (e.g. typing "1234" instead of "1243" — both are valid 4-digit numbers).

SOLUTION **Exercise 3 — Key definitions**

1. **Intranet**: A private computer network, accessible only to an organisation's members (employees, students), that uses Internet technologies (TCP/IP, HTTP, web browsers, DNS) to share information and resources internally. Example: The University of Buea's internal portal where lecturers upload course materials and students check timetables, accessible only on campus or via VPN.

2. **Tunnelling protocol**: A network protocol that encapsulates a data packet (the payload) inside another packet (the carrier) to transmit it across an intermediate network that does not support the payload's protocol or to secure it. Common examples: **IPsec** ESP (Encapsulating Security Payload), **L2TP** (Layer 2 Tunneling Protocol), **PPTP** (Point-to-Point Tunneling Protocol), and SSL/TLS-based tunnels (OpenVPN, SSTP). Example: IPsec ESP encapsulates and encrypts an IP packet inside a new IP header for secure transit over the public Internet.

3. **Firewall**: A hardware or software security system that monitors and controls incoming and outgoing network traffic based on predetermined security rules (ACLs), establishing a barrier between a trusted internal network and an untrusted external network. Example: A Cisco ASA firewall at the gateway of the Ministry of Finance blocking all inbound traffic except HTTPS to the public web server and VPN to the remote access server.

4. **Access Control List (ACL)**: A table or list attached to an object (file, folder, network resource) that specifies which subjects (users, groups, processes) are granted which permissions (read, write, execute, delete) on that object. Example: On a Linux server, the file `/etc/shadow` has an ACL allowing `root` read/write, the `shadow` group read, and all others `none`.

5. **Phishing**: A social engineering attack where the attacker masquerades as a trustworthy entity (bank, mobile money service, administrator) in an electronic communica-

tion (email, SMS, WhatsApp) to trick the victim into revealing sensitive information (passwords, PINs, card numbers) or installing malware. Example: An SMS claiming "Your MTN MoMo account is blocked, dial *123*456# to reactivate" which actually initiates a transfer to the attacker.

SOLUTION **Exercise 4 — Direct calculations**

1. Centre number: `11703` (5 digits). Weights: 6, 5, 4, 3, 2.

$$\begin{aligned}\text{Weighted sum} &= (1 \times 6) + (1 \times 5) + (7 \times 4) + (0 \times 3) + (3 \times 2)\\ &= 6 + 5 + 28 + 0 + 6 = 45\\ 45 \bmod 11 &= 1 \quad (\text{since } 11 \times 4 = 44)\\ \text{Check digit} &= 11 - 1 = 10 \rightarrow \text{X (by convention)}\\ \text{Full centre number} &= \texttt{11703X}\end{aligned}$$

2. Backup restoration scenario:
   - Policy: Full backup every Friday; Incremental backups Monday–Thursday.
   - Crash: Thursday morning (before Thursday's incremental backup runs).
   - Backup sets available: Friday (Full), Monday (Inc), Tuesday (Inc), Wednesday (Inc).
   - Number of sets to restore: 4.
   - Order of restoration:

     (a) Restore the Full backup from Friday (baseline).

     (b) Restore Monday's incremental backup (changes since Friday).

     (c) Restore Tuesday's incremental backup (changes since Monday).

     (d) Restore Wednesday's incremental backup (changes since Tuesday).

     After these four restores, the server state is recovered up to the end of Wednesday. Thursday morning's work (since last backup) is lost unless transaction logs or real-time replication were used.

SOLUTION **Exercise 5 — Classifying network scenarios**

1. **Intranet**: A private network restricted to an organisation's internal users (employees, students on campus), using Internet technologies. Access is typically controlled by firewalls and authentication; it is not accessible from the public Internet. **Extranet**: A controlled extension of an intranet that grants specific, limited access to authorised

external partners (suppliers, customers, remote staff) over the Internet, using authentication, encryption (VPN/HTTPS), and firewalls. Key difference: The user community. Intranet = internal only; Extranet = internal + authorised external entities.

2. Classification and justification:

   (a) Extranet. The portal is accessed by students from outside the school's physical network (e.g. from home or a cybercafé) using a login. It extends the school's internal information system to an external but authorised user group (enrolled students) over the public Internet.

   (b) Intranet. The email system is reachable only from the bank's branches (internal network). No access is granted to external parties or from the public Internet. It is a classic internal communication system.

   (c) Extranet. The supplier is an external partner accessing a specific resource (stock levels) of the factory in Douala via a secured login over the Internet. This is a textbook B2B extranet scenario.

SOLUTION **Exercise 6 — Working from a cybercafé**

1. Step-by-step VPN protection:

   (a) Authentication: The civil servant launches the VPN client and authenticates to the office VPN server (Yaoundé) using credentials (password), a digital certificate, or a hardware token (2FA).

   (b) Key Exchange: The client and server negotiate symmetric session keys using a protocol like IKEv2 (for IPsec) or TLS handshake (for OpenVPN/WireGuard). This ensures only the two endpoints can encrypt/decrypt the traffic.

   (c) Tunnel Creation: A virtual network interface (TUN/TAP) is created on the laptop. All IP packets destined for the office LAN (or all traffic, if full tunnel) are intercepted, encrypted (AES-GCM, ChaCha20-Poly1305), encapsulated in a new IP/UDP header (ESP for IPsec, TLS records for OpenVPN), and sent to the VPN server's public IP.

   (d) Transit: The encrypted packets traverse the cybercafé's LAN, the ISP's network, and the Internet. Any eavesdropper (cybercafé admin, ISP, hacker on Wi-Fi) sees only unintelligible ciphertext flowing to the VPN server IP. They cannot see the destination server (Yaoundé), the protocol (RDP, SSH, HTTP), or the data.

   (e) Decapsulation & Forwarding: The VPN server in Yaoundé receives packets, verifies integrity (HMAC), decrypts them, and forwards the original inner packets to the office LAN (e.g. to the file server at 192.168.1.50).

   (f) Return Path: Replies from the office server follow the reverse process: encrypted

by VPN server, sent over public network, decrypted by client.

2. Two VPN tunnel protocols:
   - **IPsec** (Internet Protocol Security) — specifically ESP (Encapsulating Security Payload) in Tunnel Mode, often combined with IKEv2 for key management.
   - **OpenVPN** (uses SSL/TLS over UDP or TCP) or **WireGuard** (modern, high-performance, kernel-space).
3. Limit: The VPN does not protect the endpoint itself. If the cybercafé computer has a keylogger, screen scraper, or malware, the attacker captures credentials before they enter the VPN tunnel. Additional precaution: Use a trusted personal device (laptop/phone) instead of the cybercafé PC; if impossible, use a live USB boot (e.g. Tails, Kali) to ensure a clean OS, and always verify the VPN server's certificate fingerprint on first connection. Disable **split tunnelling** for the session to ensure all traffic goes through the tunnel.

SOLUTION **Exercise 7 — Threats, CIA properties and countermeasures**

Threat	CIA property violated	Countermeasure
Ransomware encrypting the school's files	Availability (primary) — files inaccessible; Integrity — files altered.	Offline/immutable backups (3-2-1 rule), timely patching, application whitelisting, user training on macros/attachments.
Phishing SMS imitating a mobile money service	Confidentiality — credentials/PIN stolen; Integrity — unauthorised transactions.	User awareness training (verify sender, never share PIN), 2FA on MoMo accounts, SMS filtering/spam reporting to ANTIC (cert@antic.cm).
Denial-of-service attack on a results website	Availability — legitimate users cannot access results.	DDoS mitigation service (CDN like Cloudflare, rate limiting, anycast), redundant hosting, CAPTCHA/challenge pages.
Theft of the server from the computer room	Confidentiality (data on disks), Integrity (tampering), Availability (service down).	Physical security: locked server room, CCTV, cable locks, biometric access. Full disk encryption (BitLocker, LUKS) so stolen disks are unreadable.
Power cut during data entry	Availability (system down), Integrity (corrupted writes, half-written records).	UPS (Uninterruptible Power Supply) for graceful shutdown, generator for prolonged outages, database transactions (ACID) and journaling file systems, auto-save fea-

SOLUTION **Exercise 8 — Symmetric, asymmetric encryption and digital signature**

1. Key-distribution problem of symmetric encryption: **Symmetric encryption** requires both sender and receiver to possess the same secret key before communication begins. If they are geographically separated, they must exchange this key over a secure channel. But if they already have a secure channel to exchange the key, they often don't need encryption for the subsequent messages. Transmitting the key over an insecure channel (email, chat) allows an eavesdropper to intercept it and decrypt all future traffic. Managing unique pairwise keys for n users requires $n(n-1)/2$ keys, which becomes unmanageable at scale.

2. How asymmetric encryption solves it: **Asymmetric encryption** uses a key pair: a Public Key (K_{pub}) and a Private Key (K_{priv}).

   - The owner publishes K_{pub} openly (on a website, key server, directory).
   - Anyone wanting to send a confidential message to the owner encrypts it with K_{pub}.
   - Only the owner, who holds the mathematically linked K_{priv}, can decrypt it.
   - No secret exchange is needed beforehand; the public key can be distributed over insecure channels because it cannot decrypt messages (computationally infeasible to derive K_{priv} from K_{pub}).

   This reduces key management to n key pairs for n users.

3. Digital signature process (Delegation → School):

   (a) Hashing: The Delegation computes a cryptographic hash (digest) of the results file using a collision-resistant algorithm (e.g. SHA-256). H = Hash(File).

   (b) Signing: The Delegation encrypts the hash H with its Private Key (K^{Del}_{priv}). This encrypted hash is the Digital Signature S = Encrypt$_{K^{Del}_{priv}}(H)$. The file and S are sent to the school.

   (c) Verification (at School):

      i. The school computes the hash of the received file: H' = Hash(Received File).

      ii. The school obtains the Delegation's authentic Public Key (K^{Del}_{pub}) (via a trusted certificate / PKI).

      iii. The school decrypts the signature S using K^{Del}_{pub}: H'' = Decrypt$_{K^{Del}_{pub}}(S)$.

      iv. Comparison: If $H' = H''$, then:

         - Integrity: The file has not been altered (any change would change H').
         - Authenticity / Non-repudiation: Only the holder of K^{Del}_{priv} (the Delegation) could have produced S.

SOLUTION **Exercise 9 — Access control in a hospital — structured question (10 marks)**

1. Access Matrix (R=Read, W=Write, X=Execute, -=None)

Role	Medical Records	Appointment Schedule	Billing Data	System Configuration
Doctor	R, W	R, W	R	-
Nurse	R	R, W	-	-
Receptionist	- (or R demographics only)	R, W	R, W	-
Administrator	R (audit)	R, W	R, W	R, W, X

2. Justification using Least Privilege:

   - Doctor: Needs R/W on Medical Records for clinical care; R/W on Appointments to manage slots; R on Billing to see costs for patient counselling; No access to System Configuration (not their role, risk of misconfiguration).
   - Nurse: Needs R on Medical Records to follow doctor's orders (writing usually restricted to doctors for accountability); R/W on Appointments for ward scheduling; No access to Billing (financial separation) or Config.
   - Receptionist: No access to clinical Medical Records (confidentiality); R/W on Appointments (core duty: booking); R/W on Billing (core duty: invoicing, payments); No access to Config.
   - Administrator: R on Medical Records only for audit/backup (not clinical view); R/W on Appointments/Billing for system maintenance; R/W/X on System Configuration (sole role authorised to manage users, roles, backups, patches).

3. Why RBAC over individual user rights?

   (a) Manageability: When a nurse joins/leaves/changes ward, the admin assigns/revokes the single "Nurse" role instead of editing dozens of individual ACLs. Reduces errors and workload.

   (b) Consistency & Least Privilege: All nurses have identical, pre-approved rights. Prevents "privilege creep" where individuals accumulate rights over time.

   (c) Compliance & Audit: Easy to demonstrate to regulators (ANTIC, Health Ministry) that access follows defined policies. Supports separation of duties (e.g. no single role can both create a supplier and approve payment).

SOLUTION **Exercise 10 — Validating a GCE candidate registration form (10 marks)**

1. Validation checks per field:

Field	Validation Checks	Justification
Candidate Name	Presence (mandatory), Type (alphabetic + spaces/hyphens), Length (e.g. 2–50 chars), Format (regex: no digits, no special symbols except ' -').	Prevents empty records, injection attacks, database overflow, and nonsense entries like "John123".
Date of Birth	Presence, Type (valid date), Range (e.g. 01/01/2000 – 31/12/2010 for O/L), Cross-field (age consistent with exam level: O/L ≈ 15–17, A/L ≈ 17–19).	Ensures candidate is of eligible age; prevents future dates or 1900 entries; cross-check detects swapped day/month.
Centre Number	Presence, Type (digits + optional X), Length (exactly 6 chars), Format (5 digits + check char), Check Digit (Modulo-11 weighted algorithm).	Check digit detects single-digit errors and transpositions (common typos). Ensures only registered centres are entered.
List of Subjects	Presence (min 1, max e.g. 11), Type (valid subject codes from lookup table), Cross-field (no duplicate codes, compulsory subjects present e.g. English, French, Maths), Consistency (subject combination allowed for chosen series).	Prevents invalid codes, duplicate entries, missing compulsory subjects, and impossible combinations (e.g. "Further Maths" without "Maths").

2. Verification technique: Double Entry (Double Keying). Two different data entry operators independently type the same paper form. The system compares the two versions field by field and flags any mismatch for supervisor resolution. Error detected: Transcription errors (typos) where the entered data is syntactically valid but semantically wrong. Example: Candidate's name is "NGWA" but operator types "NGAW". Both pass validation (alphabetic, length OK), but double entry catches the discrepancy. Validation alone cannot detect this.

3. Check digit calculation for 11703: (As computed in Exercise 4) → X. Full valid number: `11703X`. Validity of entered number 11704:

- A valid centre number consists of 5 digits + 1 check character (6 characters total).
- "11704" has only 5 characters. It cannot be a complete, valid centre number.
- If "11704" is the base (first 5 digits), its check digit is calculated as: Sum = 1 × 6 + 1 × 5 + 7 × 4 + 0 × 3 + 4 × 2 = 6 + 5 + 28 + 0 + 8 = 47. 47 mod 11 = 3 (11 × 4 = 44). Check = 11 − 3 = 8. Valid full number would be `117048`.
- Conclusion: The entered string "11704" is not a valid centre number (wrong length). If the user intended to enter the base number, the system must append the computed check digit "8" to form "117048" before storage.

SOLUTION **Exercise 11 — Essay: publishing results online safely (20 marks)**

Indicative Mark Scheme and Examiner Expectations

1. Exposure choice: Extranet (4 marks)

- Correct choice: Extranet (or a public-facing website with strong authentication/authorisation, functionally an extranet).
- Justification (4 marks):
  - Students access from home/cybercafés → requires Internet accessibility (rules out pure Intranet).
  - Results contain personal data (name, DOB, grades) → must not be publicly indexable or accessible without authentication (rules out open Public Website).
  - Extranet provides controlled access: authenticated students (credentials), authorised teachers (update rights), admin (management), all over HTTPS/VPN.
  - Mention: Host on school server or trusted cloud (CAMTEL, MTN Business) with firewall restricting access to web ports (443) only.

2. HTTPS and VPN roles (4 marks)

- HTTPS (TLS 1.2/1.3): Mandatory for all users.
  - Confidentiality: Encrypts results in transit (prevents sniffing on Wi-Fi/ISP).
  - Integrity: Detects tampering (MITM injection of scripts/ads).
  - Authentication: Server certificate (verified by trusted CA) proves site identity (prevents spoofing/phishing).
  - HSTS, Secure Cookies, CSP: Harden browser behaviour.
- VPN for staff updating results remotely:
  - Teachers/admins connecting from home/cybercafé use VPN to access the admin interface (CMS, database admin).

- VPN adds network-level encryption and strong authentication (certificates + 2FA) before reaching the application layer.
- Restricts admin panel to VPN IP range only (firewall rule), hiding it from public Internet scans.
- Split tunnelling disabled for admin sessions to prevent leakage.

3. Authentication and Access-Rights Policy (4 marks)

- Students: Auth: Student ID (registration number) + strong password / PIN + 2FA (SMS OTP or authenticator app). Rights: `READ` own results only (row-level security). Least Privilege: Cannot see peers' results, cannot modify, cannot access admin pages.
- Teachers / Heads of Department: Auth: Staff ID + 2FA mandatory (hardware token or app). Rights: `READ/WRITE` results for their assigned classes/subjects only (RBAC). Least Privilege: Cannot access system config, user management, or other departments' data.
- System Administrator: Auth: Dedicated admin account (not shared), MFA, hardware token. Rights: `FULL` on infrastructure (server, DB, network, backups, user provisioning). Least Privilege: `READ ONLY` on actual result data (separation of duties — admin manages the container, not the content). Audit logs of all admin actions (immutable).

4. Validation, Verification, Integrity, Availability (4 marks)

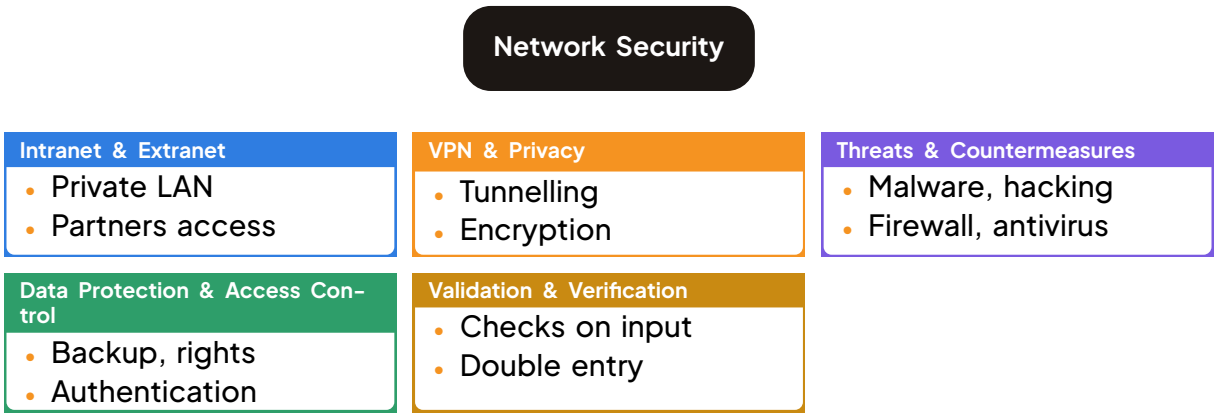
- Validation (on entry):
  - Presence/Type/Range: Marks numeric 0–20 (or 0–100), no blanks for compulsory subjects.
  - Format: Subject codes from dropdown (lookup table), no free text.
  - Cross-field: Total subjects per candidate within limits; average calculation auto-checked; duplicate subject detection; series consistency (e.g. Science student cannot enter Literature without approval).
  - Check digit: On candidate/centre numbers.
- Verification: Double Entry (Teacher enters → HOD verifies/re-enters → system compares) OR Proofreading (Teacher enters → prints mark sheet → signs physically → scanned back). Detects transcription errors validation misses.
- Integrity Guarantees:
  - Database ACID transactions (atomic updates).
  - Write-Once / Append-Only tables for final results (immutable logs).
  - Digital Signatures on exported result PDFs (hash signed by HOD's private key).
  - Audit Trail: Timestamped logs of every INSERT/UPDATE/DELETE (user, old value, new value).
- Availability Guarantees:

- Backup Strategy: Daily incremental + Weekly full (3-2-1 rule: 3 copies, 2 media, 1 off-site — e.g. CAMTEL cloud + external HDD in safe).
- High Availability: Database replication (Master-Slave) or clustering; UPS + Generator for server room.
- Disaster Recovery Plan (DRP): Tested restore procedure (RTO < 4h, RPO < 1h).
- Anti-Ransomware: Offline/immutable backups, application whitelisting, patch management.

5. Legal and Ethical Responsibility (4 marks)

- Legal (Cameroon): Law No. 2010/012 on Cybersecurity and Cybercrime (protection of personal data, obligation to secure systems, breach notification to ANTIC/CERT-CM). Draft Data Protection Bill (principles: consent, purpose limitation, data minimisation, storage limitation, security, accountability).
- Ethical: Students are minors → heightened duty of care. Results determine future (university, scholarships) → accuracy and fairness paramount. No sale/sharing of data with third parties (marketing, political) without explicit parental consent. Transparency: clear privacy policy on site. Right to rectification (appeal process for grades).
- Accountability: School Principal as Data Controller responsible for compliance. DPO (Data Protection Officer) designated if processing large scale.

16 SUMMARY SHEET



Mind map of the chapter: implementation of network security.

KEY POINTS **Key definitions**

- **Intranet**: a private network, based on Internet technologies (TCP/IP protocols, web browser, web pages), accessible only to the members of an organisation (e.g. the internal portal of a school in Yaoundé).
- **Extranet**: an extension of an intranet giving controlled access to authorised external partners (suppliers, banks, MINEDUB services), while remaining closed to the general public.
- **VPN** (Virtual Private Network): a secure encrypted tunnel created over a public network (the Internet) so that remote users communicate as if they were directly connected to the private LAN.
- **Tunnelling**: encapsulating data packets inside encrypted packets so that they can cross an insecure network safely.
- **Firewall**: hardware or software placed between networks that filters incoming and outgoing traffic according to a set of security rules.
- **Malware**: any malicious software designed to harm or exploit a system (virus, worm, Trojan horse, ransomware, spyware).
- **Authentication**: the process of proving one's identity (password, PIN, biometrics, security token).
- **Authorisation**: the access rights granted to an authenticated user (read, write, execute).

- **Encryption**: transforming data into an unreadable form using a key; only the correct key can decrypt it.
- **Validation**: an automatic check, performed by the program, that entered data is reasonable and acceptable (correct format, within an allowed range).
- **Verification**: checking that data has been copied or entered correctly, i.e. that it matches the original source (double entry, visual check, proofreading).

KEY POINTS **Facts and mechanisms to know**

- Main threats: viruses, worms, Trojan horses, phishing, hacking, spoofing, denial of service (DoS), social engineering, interception of data.
- Countermeasures: firewall, up-to-date antivirus, strong passwords, encryption, regular backups, user access rights, software updates, user sensitisation and training.
- Security goals (the **CIA triad**): Confidentiality (only authorised persons read the data), Integrity (data is not altered), Availability (data and services remain accessible).
- VPN protocols: PPTP, L2TP/IPsec, SSL/TLS (used by OpenVPN). Encryption in a VPN provides confidentiality, integrity and authenticity of the exchanged data.
- Backup types: full (everything copied), incremental (only changes since the last backup of any type), differential (all changes since the last full backup).
- Validation checks: presence, data type, range, format, length, check digit, consistency (cross-field).
- Verification techniques: double data entry (data typed twice and the two versions compared) and visual checking / proofreading (comparing the entered data with the source document).

METHOD **Securing a network and choosing a validation check**

To secure a network (layered defence):

1. Identify the assets to protect (data, servers, user accounts).
2. Identify the threats and vulnerabilities affecting those assets.
3. Apply defence in depth: firewall + antivirus + access control (authentication and authorisation) + regular backups + user training.

4. Monitor, update and test the measures regularly.

To choose a suitable validation check:

1. Ask: “what could go wrong with this input?”
2. Match the risk to the check: e.g. an age must lie between 5 and 25 → range check; a date must be written DD/MM/YYYY → format check; a compulsory field left empty → presence check.
3. In the exam, name the check and justify it using the data given in the question.

WARNING **Common mistakes**

- Confusing intranet (internal users only) with extranet (internal users + selected authorised outsiders).
- Believing a VPN makes you fully anonymous: it encrypts the traffic, but the VPN provider can still see your activity.
- Mixing up validation and verification in exam answers: validation = data is plausible; verification = data has been accurately transferred from the source.
- Confusing incremental backups (changes since the last backup) with differential backups (changes since the last full backup).
- Thinking a firewall alone stops viruses: a firewall filters network traffic; it does not scan files for malware – that is the role of the antivirus.

METHOD **GCE examination tips**

- Define terms precisely and always give one concrete example (mobile money PIN as authentication, a VPN used by remote workers of MTN or Orange, a school intranet portal).
- For “state a suitable check” questions, name the check and justify it with the data given in the question.
- When discussing security goals, distinguish clearly between confidentiality, integrity and availability (the CIA triad).
- In structured questions, answer in short numbered points: one mark usually corresponds to one valid, clearly stated point.

Signed • OnBuch+
ONBUCH+ TEACHING TEAM
FOLLOWS THE OFFICIAL MINESEC SYLLABUS

OnBuch+